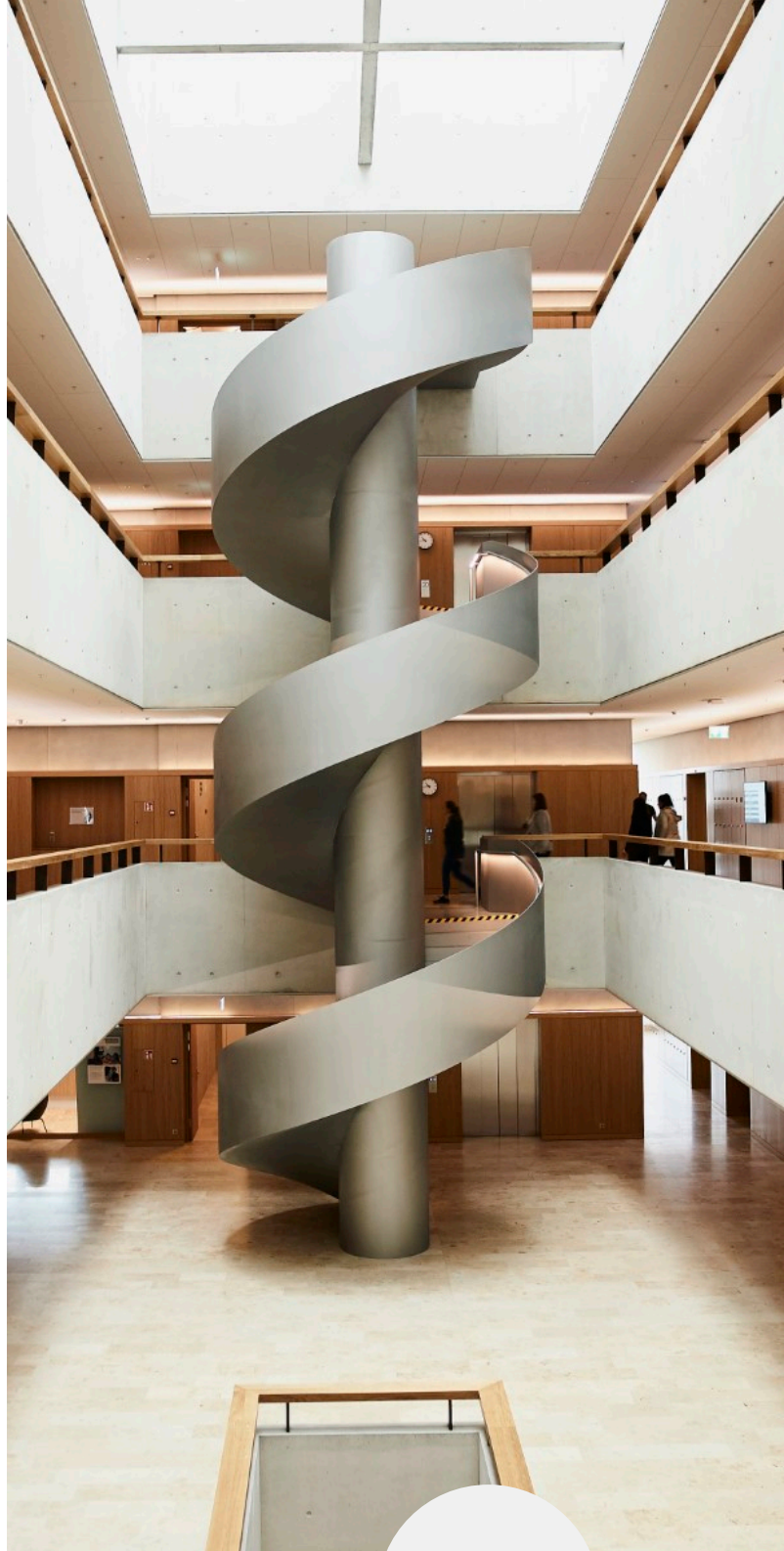


Lösungen Laborübung

Public Key Infrastructure



Version
1.5.0

I. Allgemeine Informationen

Name:

Gruppe:

Bemerkungen:

Autoren

T. Jösler, E. Sturzenegger, F. Arnold

Version

Letzte Änderung: 2026-03-12

Dokument Version: 1.5.0 (#9b161ee)

Template Version: 2.2.3 (#e76489c6)

Copyright Informationen

Alle Rechte vorbehalten

II. Inhaltsverzeichnis

1. Vorbereitung	4
1.1. Einleitung	4
1.2. Zeitliche und organisatorische Hinweise	4
1.3. Lernziele	4
1.4. Hausaufgaben	4
1.5. Theorie	5
1.6. Benötigte Mittel	6
1.7. Versuchsumgebung	7
1.8. Vorbereitungsaufgaben	7
1.9. Tipps & Tricks	8
2. Certification Authority (CA) installieren & konfigurieren	10
3. HTTPS aktivieren	25
4. Certificate Authentication	29
4.1. Webserver konfigurieren	29
4.2. User Certificate Autoenrollment	30
4.3. Certificate Revocation	32
5. Code Signing	40
5.1. Standardverhalten von PowerShell-Scripts	40
5.2. Execution Policy anpassen	42
5.3. Code-Signing-Zertifikate ausstellen	43
5.4. Script signieren	46
5.5. Revocation-Problematik	47
6. SSL Interception	49
6.1. mitmproxy	49
6.2. Windows-Client vorbereiten	51
6.3. Testing	51
6.4. Eigene Certificate Authority einbinden	52
6.5. Testing zum Zweiten	53
6.6. Funktionsanalyse	53
6.7. Aufräumen	54
6.8. Schlusswort	54
7. Anhang	56
7.1. Anhang A – Ablauf Signieren	56
7.2. Anhang B: Zertifikatsbasierte, gegenseitige Authentifizierung	56

III. Vorwort

Feedback

Mit Ihrer Mithilfe kann die Qualität des Versuches laufend den Bedürfnissen angepasst und verbessert werden.

Falls in diesem Versuchsablauf etwas nicht so funktioniert wie es beschrieben ist, melden Sie dies bitte direkt dem Laborpersonal oder erwähnen Sie es in Ihrem Laborbericht oder Protokoll. Behandeln Sie die zur Verfügung gestellten Geräte mit der entsprechenden Umsicht.

Bei Problemen wenden Sie sich bitte ebenfalls an das Laborpersonal.

Legende

In den Versuchen gibt es Passagen, die mit den folgenden Boxen markiert sind. Diese sind wie folgt zu verstehen:

Wichtig

Dringend beachten. Was hier steht, unbedingt merken oder ausführen.

Aufgabe III.1

Beantworten und dokumentieren Sie die Antworten im Laborprotokoll.

Hinweis

Ergänzender Hinweis / Notiz / Hilfestellung.

Information

Weiterführende Informationen. Dies sind Informationen, die nicht zur Ausführung der Versuche benötigt werden, aber bekannt sein sollten.

Story

Hierbei wird die Geschichte vermittelt, die in den Versuch einleitet oder den Zweck des Versuches vorstellt.

Zielsetzung

Lernziele, die nach dem Bearbeiten des Kapitels erfüllt sein sollten.

Erkenntnis

Wichtige Erkenntnisse, die aus dem Versuch mitgenommen werden sollten.

1. Vorbereitung

1.1. Einleitung

Diese Laborübung soll den Studierenden den praktischen Umgang mit einer Public Key Infrastructure näherbringen. Dabei werden die Studierenden das praktisch Umgesetzte immer wieder mit den gelernten theoretischen Grundlagen verifizieren. Während in einem ersten Teil eine Certification Authority installiert und konfiguriert, sowie eine Webseite HTTPS-fähig gemacht wird, steht im zweiten Teil der Übung die Authentifizierung von Usern und die Verifikation von Dateien mittels eines Zertifikats im Mittelpunkt. Im letzten Teil der Übung wird aufgezeigt, wie einfach SSL-Interception betrieben werden kann und was dies für Auswirkungen auf das vermeintlich sichere Surfen über HTTPS hat.

Auf das Themengebiet “verschlüsselte E-Mails” wird in dieser Übung verzichtet. Dieses Themengebiet ist bereits Lerngegenstand anderer Module.

1.2. Zeitliche und organisatorische Hinweise

Für diese Übung ist ein Zeitfenster von sechs Unterrichtslektionen vorgesehen. Je nach persönlichem Interesse oder entsprechendem Vorwissen kann dies auch über/unter die genannte Zeitangabe hinausgehen.

Die vorliegende Übung wird als Partnerarbeit durchgeführt.

1.3. Lernziele

Zielsetzung

Nach Abschluss dieser Laborübung können Sie ...

- die grundlegenden Konzepte einer Public Key Infrastructure (PKI) erklären und deren Bedeutung für die IT-Sicherheit bewerten.
- eine Certification Authority (CA) unter Windows installieren, konfigurieren und verwalten.
- Zertifikate ausstellen und HTTPS auf einem Webserver konfigurieren.
- zertifikatsbasierte Authentifizierung für Webserver einrichten und Benutzerzertifikate automatisiert ausstellen.
- Zertifikate widerrufen und die Auswirkungen auf die Authentifizierung mit Certificate Revocation Lists (CRL) und Online Certificate Status Protocol (OCSP) analysieren.
- die Funktionsweise von Code-Signing verstehen und eigene Skripte mit digitalen Signaturen schützen.
- mit mitmproxy eine Man-in-the-Middle-Attacke auf HTTPS-Verbindungen durchführen und analysieren.
- die Sicherheitsrisiken von SSL-Interception bewerten und Massnahmen zur Absicherung sensibler Kommunikation vorschlagen.

1.4. Hausaufgaben

Dieses Kapitel beschreibt die Vorbereitungsmaßnahmen, die Sie vor Beginn des Laborversuches durchführen müssen.

Lesen Sie zur Vorbereitung auf die Laborübung die unter **Theorie** aufgelisteten Quellen und beantworten Sie die Theoriefragen.

1.5. Theorie

Lesen Sie das Kapitel 1 des Buches Sicherheit und Kryptographie im Internet - Theorie und Praxis; 4., überarbeitete und erweiterte Auflage von Jörg Schwenk.

Aus dem Hochschul-Netzwerk können Sie das Buch gratis als PDF herunterladen: https://link.springer.com/chapter/10.1007/978-3-658-06544-7_1

1.5.1. Fragen zur Theorie

Beantworten Sie die folgenden Fragen und notieren Sie Ihre Antworten. Sie finden die nötigen Informationen, um die Fragen zu beantworten im oben erwähnten Buch, im Anhang oder auch im grossen bösen Internet.

Aufgabe 1.1

Wie unterscheiden sich symmetrische und asymmetrische Verschlüsselung? Nennen Sie für beide mindestens je zwei Eigenschaften.

Lösung

Symmetrische Verschlüsselung verwendet denselben Schlüssel für Ver- und Entschlüsselung. Asymmetrische Verschlüsselung verwendet verschiedene Schlüssel.

Symmetrische Verschlüsselung basiert auf einem pre-shared Key, asymmetrische auf einem Schlüsselaustauschverfahren.

Symmetrische Verschlüsselung ist performanter als asymmetrische Verschlüsselung.

Aufgabe 1.2

Was für Authentifizierungsmechanismen existieren? Erklären Sie die jeweilige Funktionsweise jeweils mit ein bis zwei Sätzen.

Lösung

Etwas wissen (Passwort), etwas sein (Biometrie), etwas haben (Schlüssel)

Aufgabe 1.3

Wie ist ein handelsübliches X.509-Zertifikat aufgebaut? Was für Felder kommen vor? Beschreiben Sie!

Lösung

Gültigkeitsbereich (Datum)
Fingerprint
Subject/SAN
Anwendungsbereich
Issuer
Organisation
Seriennummer
Signatur Algorithmus

Aufgabe 1.4

Wie funktioniert das Signieren einer Nachricht? Erklären Sie welche Komponenten beim Sender sowie beim Empfänger welche Rolle spielen. (siehe [Anhang A – Ablauf Signieren](#))

Lösung

Es wird ein Hash der Nachricht erstellt. Der Hash wird mit dem privaten Schlüssel des Senders verschlüsselt.
Der Empfänger erstellt einen Hash der erhaltenen Nachricht. Der verschlüsselte Hash vom Sender kann mit dem öffentlichen Schlüssel des Senders entschlüsselt werden. Wenn Hashes übereinstimmen wurde die Nachricht nicht verändert.

Aufgabe 1.5

Was gibt es für Möglichkeiten, ein Zertifikat für ungültig zu erklären?

Lösung

- Das Zertifikat läuft ab.
- Das Zertifikat wird revoziert.
- Die CA, welche das Zertifikat erstellt hat ist nicht mehr gültig (und damit alle ausgestellten Zertifikate auch nicht mehr).

1.6. Benötigte Mittel

Im Rahmen dieser Laborübung werden keine speziellen Hardwareressourcen benötigt. Sämtliche Aufgaben werden auf Laborgeräten bzw. auf virtuellen Maschinen durchgeführt. Bei Bedarf kann auch das eigene Gerät verwendet werden.

1.7. Versuchsumgebung

Sie erhalten zu Beginn der Übung folgende Arbeitsumgebung, welche auf Basis von virtuellen Maschinen auf Servern von Lab Services umgesetzt ist:

Windows-Server: Das Active Directory (AD) läuft unter Windows Server 2022 und ist als Domänencontroller (DC) für die Domäne `gXXX.ckteck.com` eingerichtet (XXX entspricht Ihrer Gruppennummer). Auf diesem Host werden Sie die Certificate Authority konfigurieren.

Windows-Client: Auf dem Windows-Client ist für diese Übung ebenfalls ein Windows Server 2022 vorinstalliert und der Client ist bereits in die Domäne eingebunden. In der Praxis könnte es sich dabei aber auch um ein Windows 10 oder Windows 11 System handeln. Von diesem Host aus werden Sie auf eine mit Zertifikat gesicherte Webseite zugreifen.

Linux-Client: Auf dem Linux-Client ist Debian 12 (bookworm) als Betriebssystem installiert. Von diesem Host aus werden Sie auf eine mit Zertifikat gesicherte Webseite zugreifen.

1.8. Vorbereitungsaufgaben

In diesem Kapitel werden vorbereitende Aktionen durchgeführt, damit die Übung funktioniert.

Loggen Sie sich auf Ihrem Domain Controller ein. Nutzen Sie den Account **labadmin**.

Öffnen Sie den **DNS Manager**. Sie finden diesen in den **Windows Administrative Tools** unter dem Namen **DNS**.

Erstellen Sie einen A-Record in der Forward Lookup Zone "`gXXX.ckteck.com`". Dabei entspricht der Teil **gXXX** Ihrer Gruppennummer. Navigieren Sie dazu durch den Baum auf der linken Seite des Fensters und erstellen Sie einen neuen Host-Eintrag mit Hilfe des Kontextmenüs der rechten Seite des Fensters.

Wählen Sie als Name "`www`". Der Rest Ihrer Domäne wird automatisch ergänzt. Bringen Sie die private IPv4-Adresse Ihres **Linux-Clients** in Erfahrung, z. B. mit `nslookup lc-XXX.islab.ls.eee.intern`. Tragen Sie diese ein und erstellen Sie den A-Record. Nun kann Ihr Linux-Client / -Webserver auch mittels DNS-Namen angesprochen werden. Dies werden Sie im Kapitel "HTTPS aktivieren" brauchen.

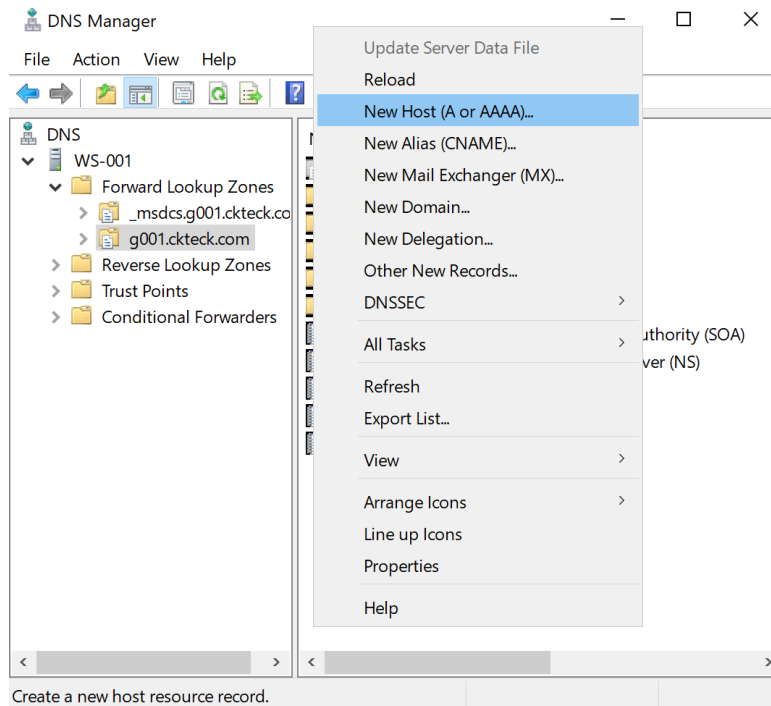


Abbildung 1: Erstellen eines neuen A-Records im “DNS Manager”

1.9. Tipps & Tricks

Nachfolgend finden Sie Hinweise und häufige Fehler die bei der Problemlösung behilflich sein können.

1.9.1. Allgemeines

- Achten Sie sich beim Verbinden via RDP oder SSH stets auf die korrekte Gruppennummer.
- Achten Sie sich bei Befehlen darauf, Platzhalter wie `XXX` (z.B. `gXXX` -> `g007`) durch Ihre Gruppennummer zu ersetzen.
- Stellen Sie zudem sicher, dass Sie jeweils die korrekte Instanz verwenden (`ws-XXX` vs. `wc-XXX`).
- Kontrollieren Sie nach dem Einfügen von Befehlen und Codesnippets stets, ob alles korrekt übertragen wurde. Leerschläge oder Sonderzeichen könnten fehlen oder falsch übernommen werden.
- Prüfen Sie insbesondere Passwörter sorgfältig. Häufige Probleme:
 - Beim Kopieren aus PDFs können einzelne Zeichen am Anfang oder Schluss fehlen.
 - Der Bindestrich kann Fehler verursachen. Ersetzen Sie diesen manuell durch einen herkömmlichen Bindestrich (`-`).

Hinweis

Kopieren Sie Befehle oder Passwörter zuerst in Ihren lokalen Texteditor. Prüfen und korrigieren Sie diese dort, bevor Sie sie in die CLI einfügen.

1.9.2. Vorgehen bei Problemen

Hinweis

Gewisse Probleme lassen sich durch das Neustarten der entsprechenden Instanz beheben.

1. **Kontrollieren Sie zuerst sorgfältig, ob alle vorherigen Schritte vollständig und korrekt ausgeführt wurden.** Die meisten Fehler lassen sich so beheben.
2. Prüfen Sie System- oder Anwendungslogs auf Fehlermeldungen oder Hinweise zur Fehlerursache.
3. Wenn Sie das Problem nicht selbst beheben können, kontaktieren Sie uns via Discord-Channel.

Beschreiben Sie dabei das Problems möglichst genau, z.B.:

- Absatz- und/oder Aufgabennummer
- Ausgeführter Befehl sowie die erhaltene Fehlermeldung

2. Certification Authority (CA) installieren & konfigurieren

Zuerst muss die Rolle **“Active Directory Certificate Services”** installiert werden. Über den Server Manager kann der **“Add Roles and Features”**-Wizard gestartet werden. Als **“Installation Type”** wählen Sie **“Role-based or feature-based Installation”** und bei der **“Server Selection”** Ihren Domänencontroller **ws-XXX.gXXX.ckteck.com**. Bei den **“Server Roles”** aktivieren Sie die Rolle **“Active Directory Certificate Services”**:

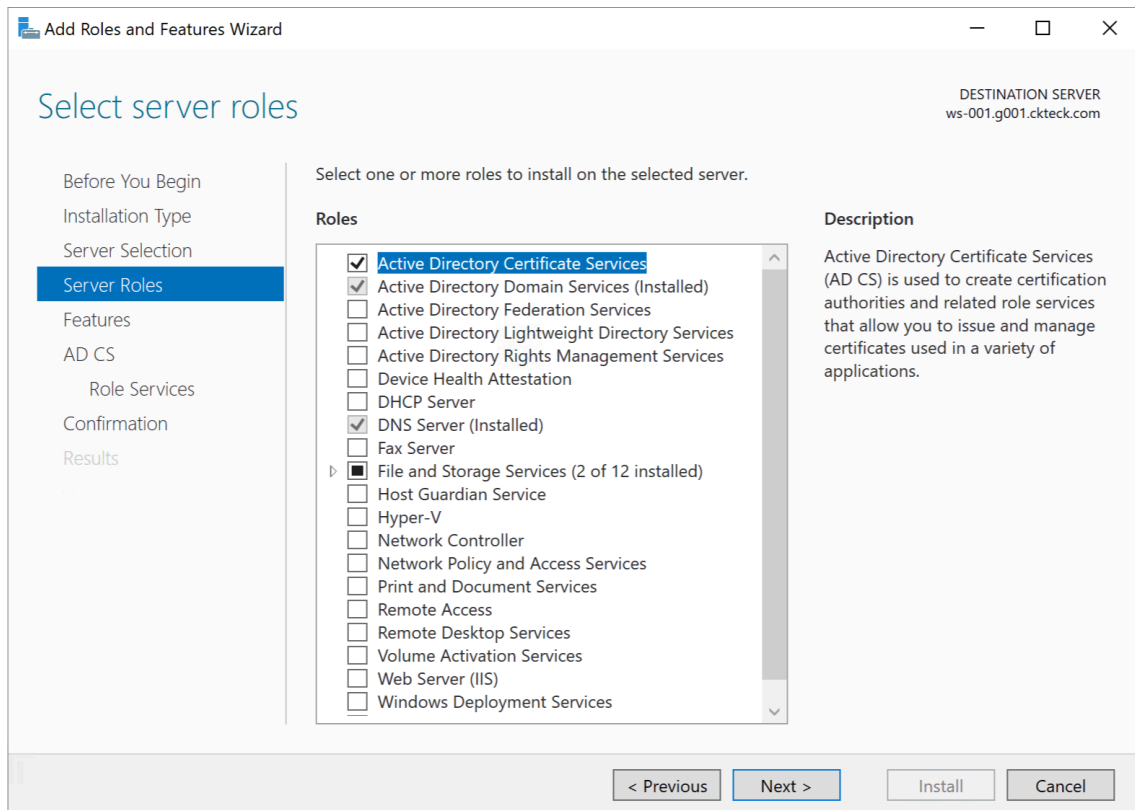


Abbildung 2: Auswahl der “Server Roles”

Alle Rückfragen mit **“Add features that are required for [...]”** können Sie mit einem Klick auf **“Add Features”** bestätigen. Von den zur Verfügung stehenden **“AD CS Role Services”** werden die Folgenden benötigt:

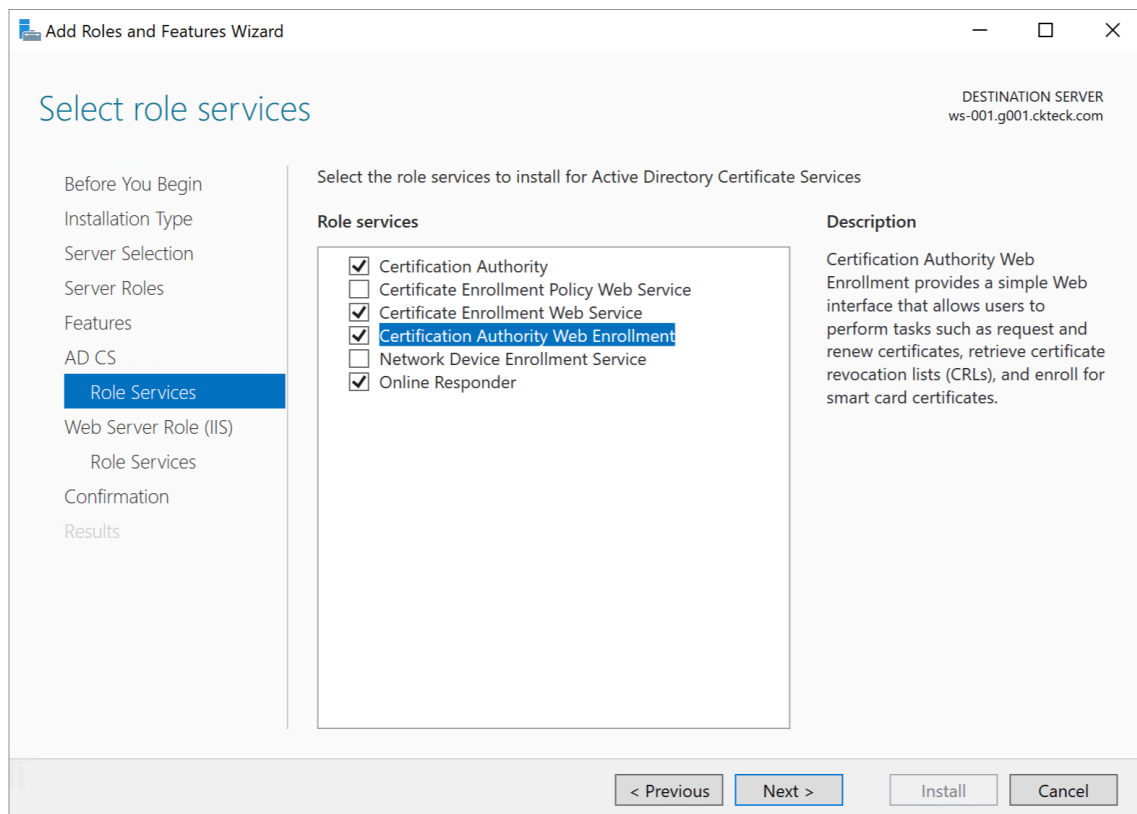


Abbildung 3: Auswahl der “Role Services”

Ansonsten sind keine Änderungen an den Standardeinstellungen notwendig. **Die Installation kann einige Zeit dauern** – gönnen Sie sich einen circa 5-minütigen Kaffee. Starten Sie Ihren Server neu, falls ein Neustart verlangt wird. Es kann einige Minuten dauern, bis alle Änderungen vorgenommen und Ihr Server neugestartet ist. Haben Sie Geduld.

Nach der erfolgreichen Installation müssen die Services noch via Server Manager konfiguriert werden. Der Dialog dafür befindet sich im Server Manager und sieht folgendermassen aus:

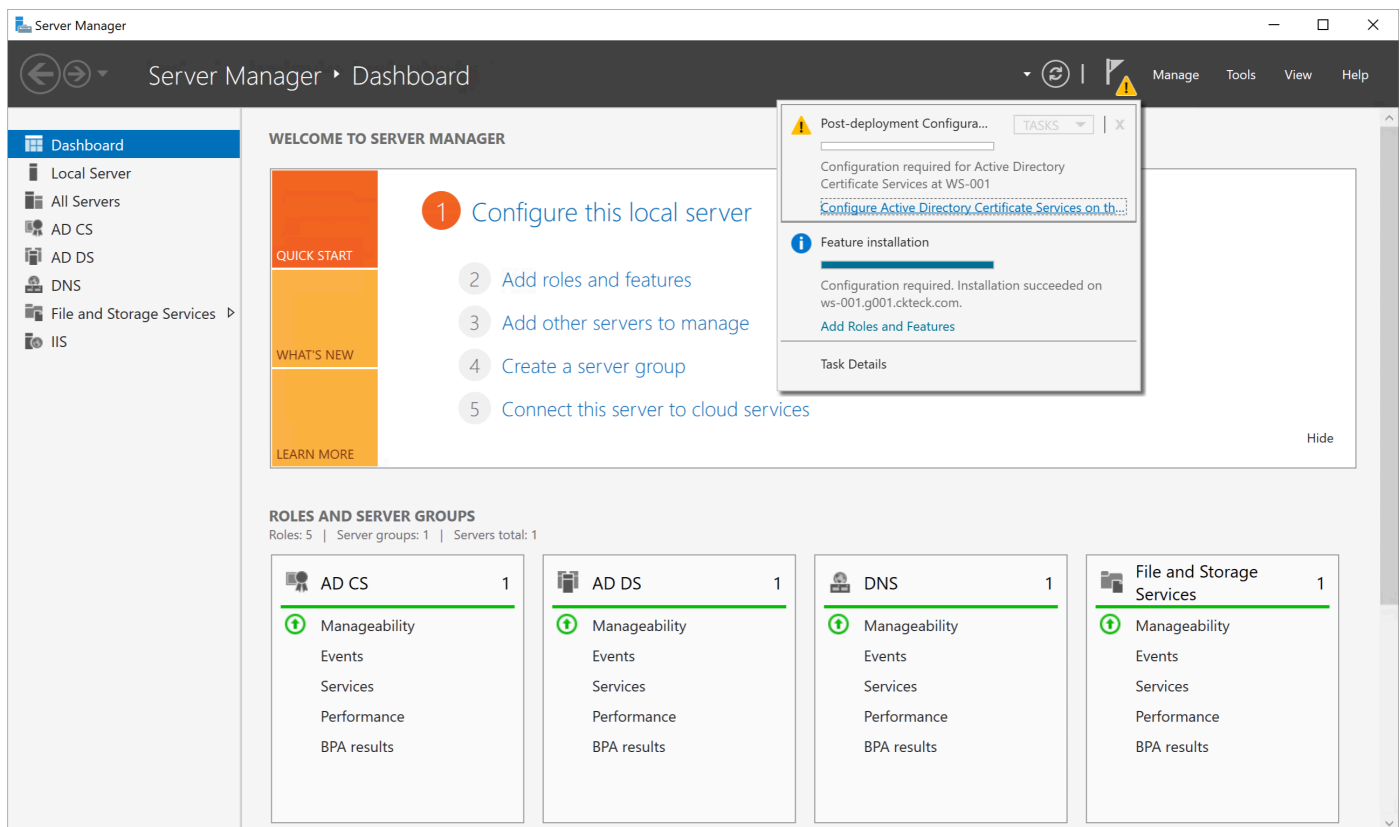


Abbildung 4: Start der “Post-deployment Configuration”

Begonnen wird mit dem Role Service “**Certification Authority**”. Die anderen Role Services werden in dieser Übung nach und nach konfiguriert.

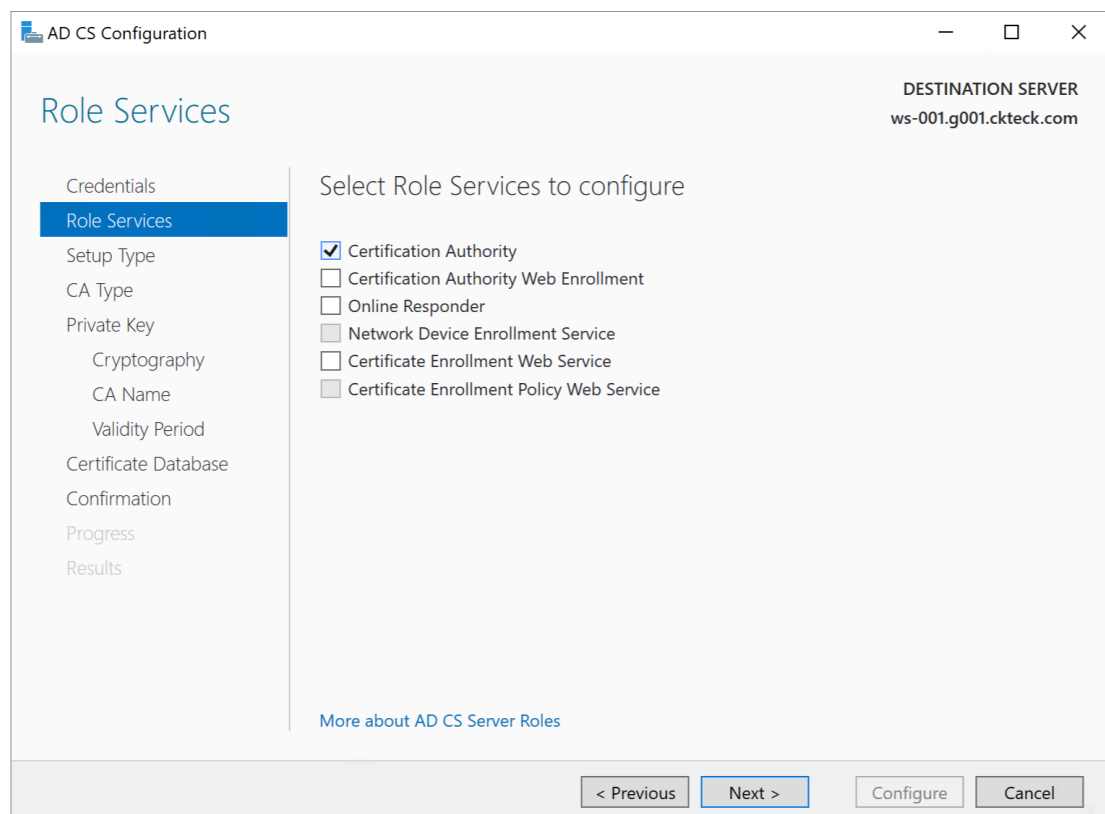


Abbildung 5: Auswahl der zu konfigurierenden “Role Services”

Es soll eine **Enterprise CA** installiert werden. Diese sind Mitglieder einer Domäne und können Domänenmitglieder mit diversen Zertifikaten ausrüsten. Da Ihr Windows-Server zeitgleich als Domain Controller fungiert, ist dieser bereits Teil der Domäne. Ansonsten müsste Ihr Server zuerst in Ihre Domäne aufgenommen werden.

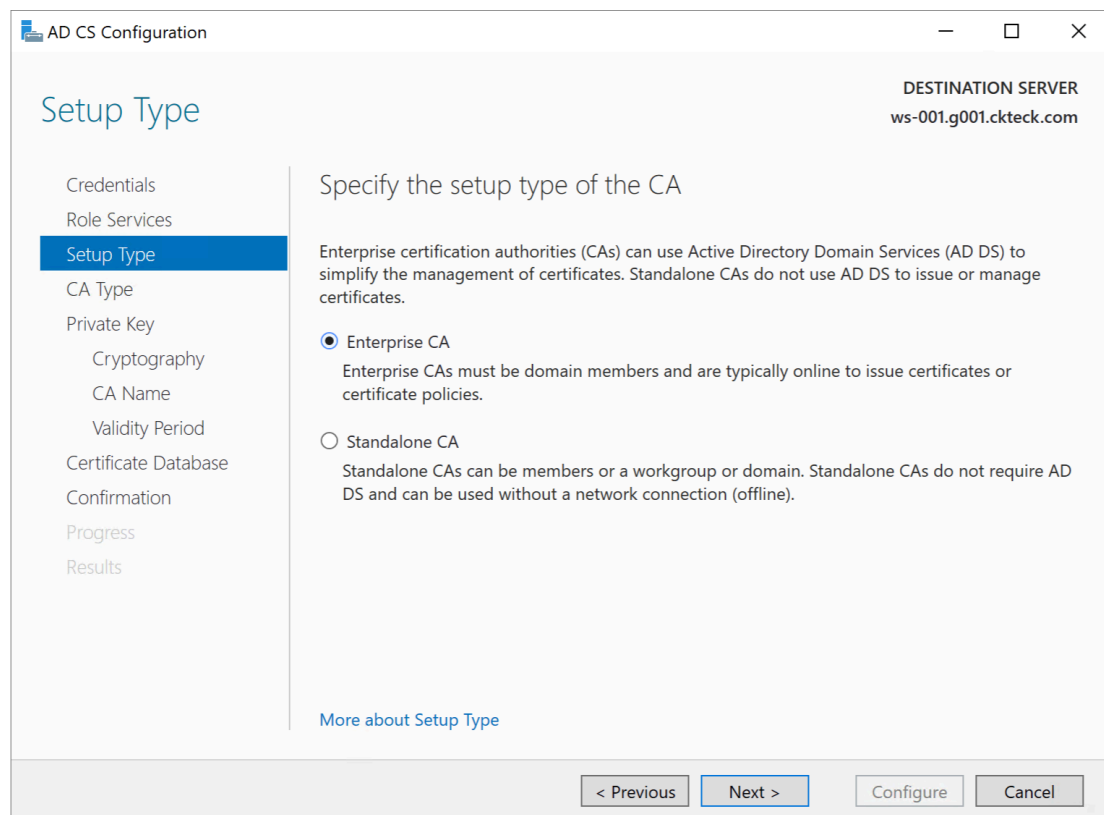


Abbildung 6: Auswahl des CA “Setup Type”

Grundsätzlich gibt es verschiedene Architekturen, wie eine PKI-Infrastruktur betrieben werden kann. Dies reicht von einer Single-Tier- bis Three-Tier-Hierarchie. Mehr Informationen zum Design von PKI-Infrastrukturen finden sich auf folgender Webseite: <https://techcommunity.microsoft.com/t5/ask-the-directory-services-team/designing-and-implementing-a-pki-part-i-design-and-planning/ba-p/396953>

Der Einfachheit halber verwenden wir in diesem Versuch eine Two-Tier-Hierarchie. In diesem Kapitel werden wir eine Issuing- oder auch Subordinate-CA installieren. Diese bezieht Ihr Zertifikat von einer Root CA. Diese wurde bereits vom Laborteam installiert. Normalerweise wird die Root CA nur für das Ausstellen der Zertifikate der Issuing CAs benötigt. Zur übrigen Zeit wird die Root CA aus Sicherheitsgründen ausgeschaltet.

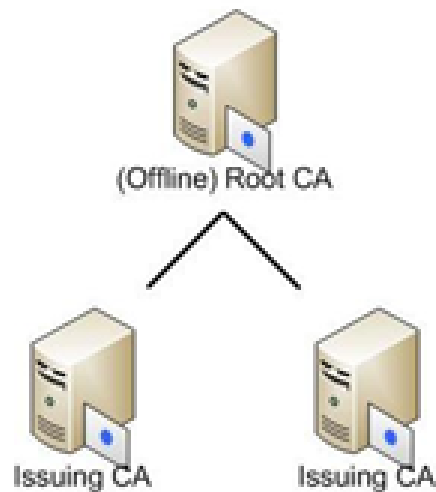


Abbildung 7: Two-Tier-PKI-Hierarchie (Quelle: <https://techcommunity.microsoft.com/t5/ask-the-directory-services-team/designing-and-implementing-a-pki-part-i-design-and-planning/ba-p/396953>)

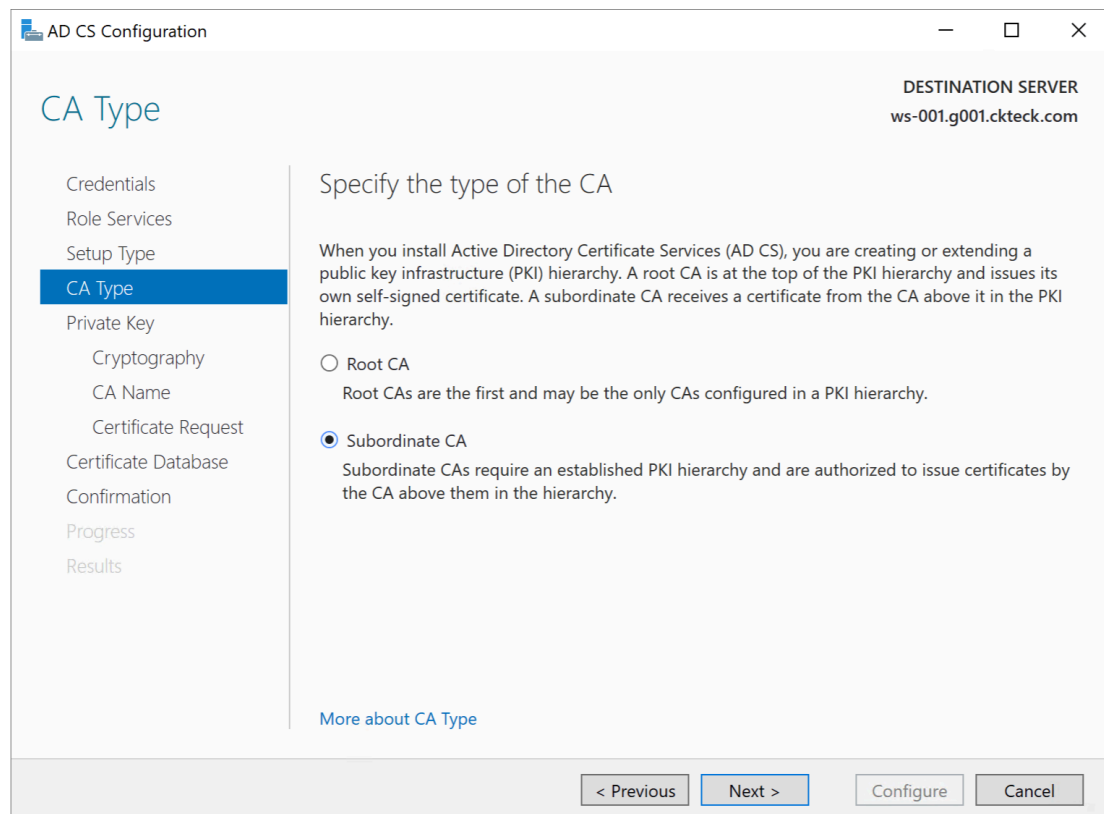
Aufgabe 2.1

Warum sollte die Root CA die meiste Zeit ausgeschaltet, respektive offline sein? Was gibt es hier für Sicherheitsbedenken? Begründen Sie!

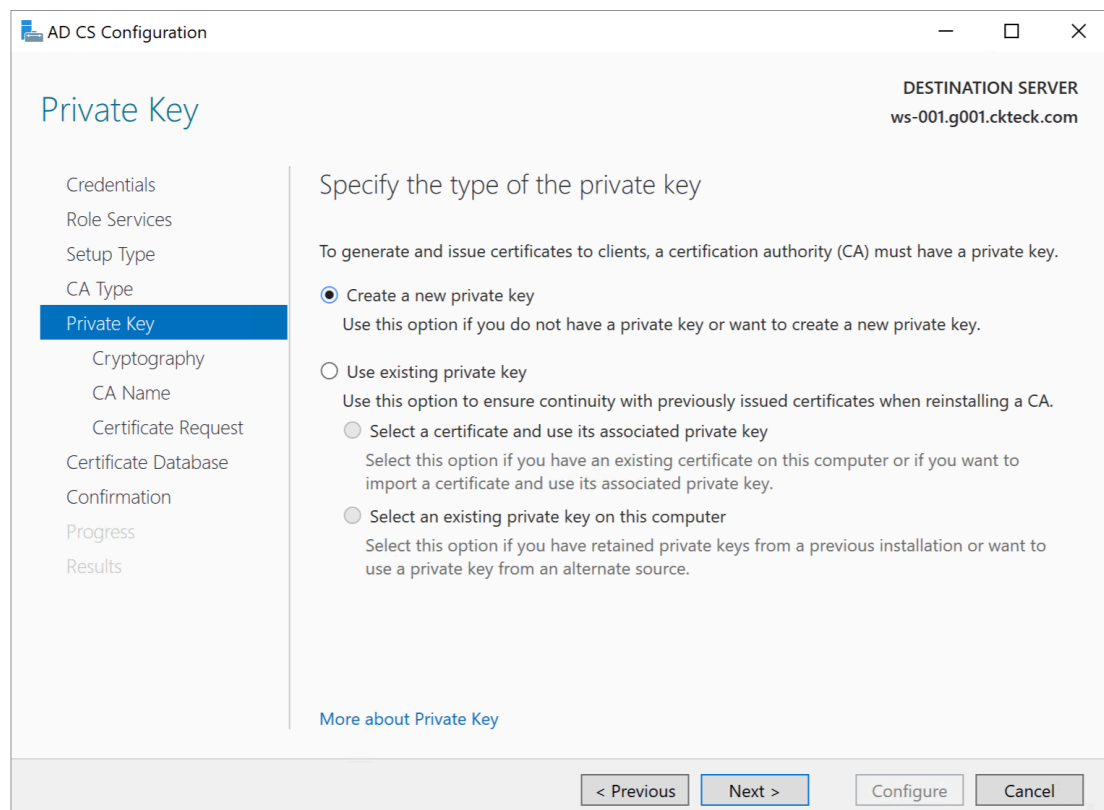
Lösung

Wird eine Root CA kompromittiert, gilt die komplette PKI dieser Root CA als kompromittiert (alle Subordinates und alle Zertifikate). Je öfter die Root CA online ist, desto grösser ist die Angriffsfläche.

Wählen Sie nun “**Subordinate CA**” als CA-Typ aus:

**Abbildung 8:** Auswahl des CA Typs

Erstellen Sie einen neuen Private Key. Wählen Sie eine Schlüssellänge von **4096 Bits**. Als Algorithmus belassen Sie **SHA256**.

**Abbildung 9:** Auswahl des Private Key Typs

Wählen Sie einen sprechenden Namen für Ihre neue CA, beispielsweise “CKTECK CA”:

AD CS Configuration

DESTINATION SERVER
ws-001.g001.ckteck.com

CA Name

Credentials
Role Services
Setup Type
CA Type
Private Key
Cryptography
CA Name
Certificate Request
Certificate Database
Confirmation
Progress
Results

Specify the name of the CA

Type a common name to identify this certification authority (CA). This name is added to all certificates issued by the CA. Distinguished name suffix values are automatically generated but can be modified.

Common name for this CA:
CKTECK CA

Distinguished name suffix:
DC=g001,DC=ckteck,DC=com

Preview of distinguished name:
CN=CKTECK CA,DC=g001,DC=ckteck,DC=com

[More about CA Name](#)

< Previous Next > Configure Cancel

Abbildung 10: Auswahl eines Namens für die CA

Generieren Sie als nächstes einen Certificate Signing Request (CSR) und speichern Sie ihn lokal ab. Der Rest der Installation kann mit den Standardeinstellungen beendet werden.

Der Results-Tab gibt Auskunft über die nächsten Schritte, die Sie zur Konfiguration unternehmen müssen. Die Meldung, ob weitere Role Services konfiguriert werden sollen, kann mit “No” beantwortet werden. Die verbleibenden Role Services werden später konfiguriert.

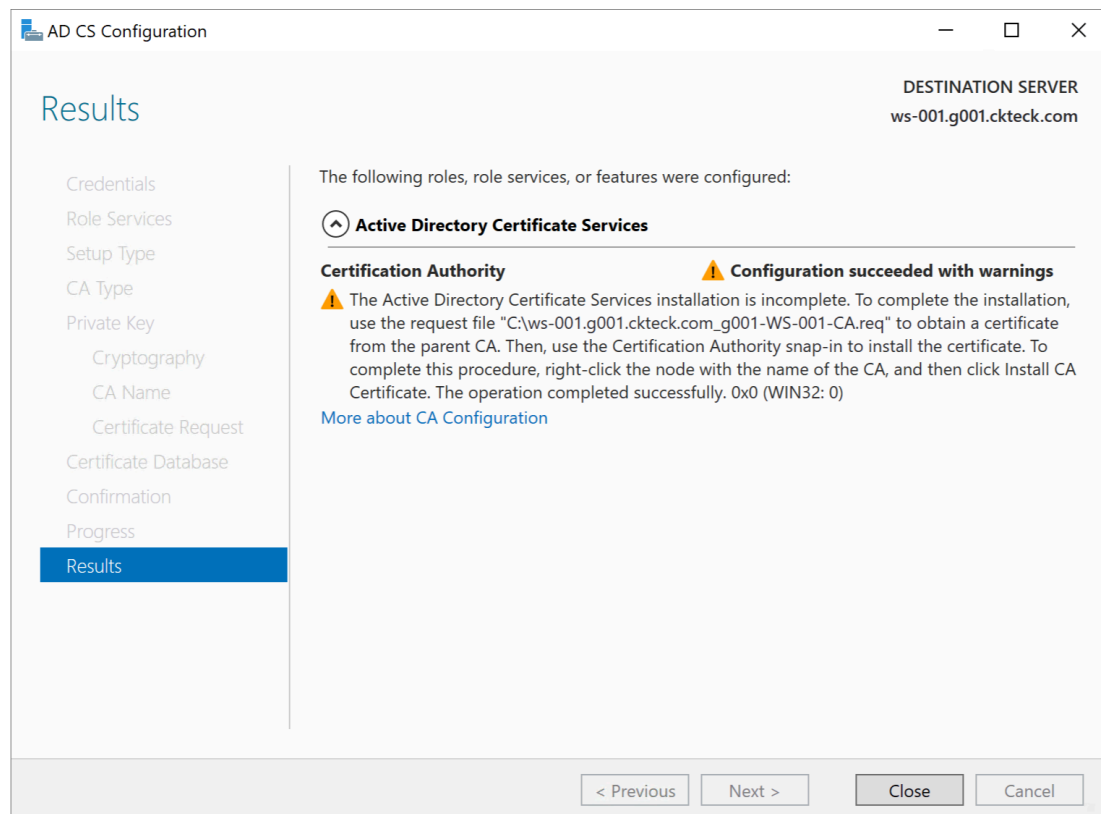


Abbildung 11: Ansicht der Resultate nach abgeschlossener CA Konfiguration

Im Vorfeld dieser Übung wurde vom Assistenzteam bereits eine Root CA aufgesetzt, von welcher Sie nun Ihr Subordinate Certificate lösen können. Navigieren Sie dazu zu folgender URL:

<http://ckteckca.islab.ls.eee.intern/certsrv/>.

Laden Sie als erstes das Zertifikat der Root CA herunter. Sie finden es unter “Download a CA certificate...”. **Laden Sie es in BASE64-codierter Version herunter!** Das Zertifikat werden wir später benötigen. Benennen Sie die Datei so, dass Sie später noch wissen, welches Zertifikat diese Datei beinhaltet.

Gehen Sie nun zurück auf die Ausgangsseite und navigieren Sie folgendermassen: **Request a certificate → advanced certification request → submit a request**

Kopieren Sie nun den Inhalt des zuvor generierten **Certificate Signing Requests** in das “Saved Request”-Feld und klicken Sie auf “Submit”. Theoretisch müssten Sie sich nun auf der Root CA einloggen und den Certificate Request bestätigen. Da aber für alle Kursteilnehmenden nur eine Root CA existiert, wäre das ziemlich chaotisch. Darum wurde diese Root CA so konfiguriert, dass Zertifikate automatisch ausstellt werden. Dies ist sicherheitstechnisch eine üble Sache und sollte ausserhalb dieser Übungsumgebung niemals so konfiguriert werden!

Laden Sie nun die für Sie bereitgestellte **Certificate Chain** im **BASE64-encodierten Format** herunter.

Als nächstes muss das “Certification Authority”-Konfigurationsfenster geöffnet werden. Sie finden dieses im Startmenü unter “Windows Administrative Tools”. Installieren Sie die heruntergeladene Certificate Chain mittels Rechtsklick auf “CKTECK CA” (Name kann abweichen) → All Tasks → Install CA Certificate. Wählen Sie die zuvor beantragte und heruntergeladene Certificate Chain **certnew.p7b** aus. Bestätigen Sie die Meldung beginnend mit “The root certificate is untrusted.” mit einem Klick auf “OK”.

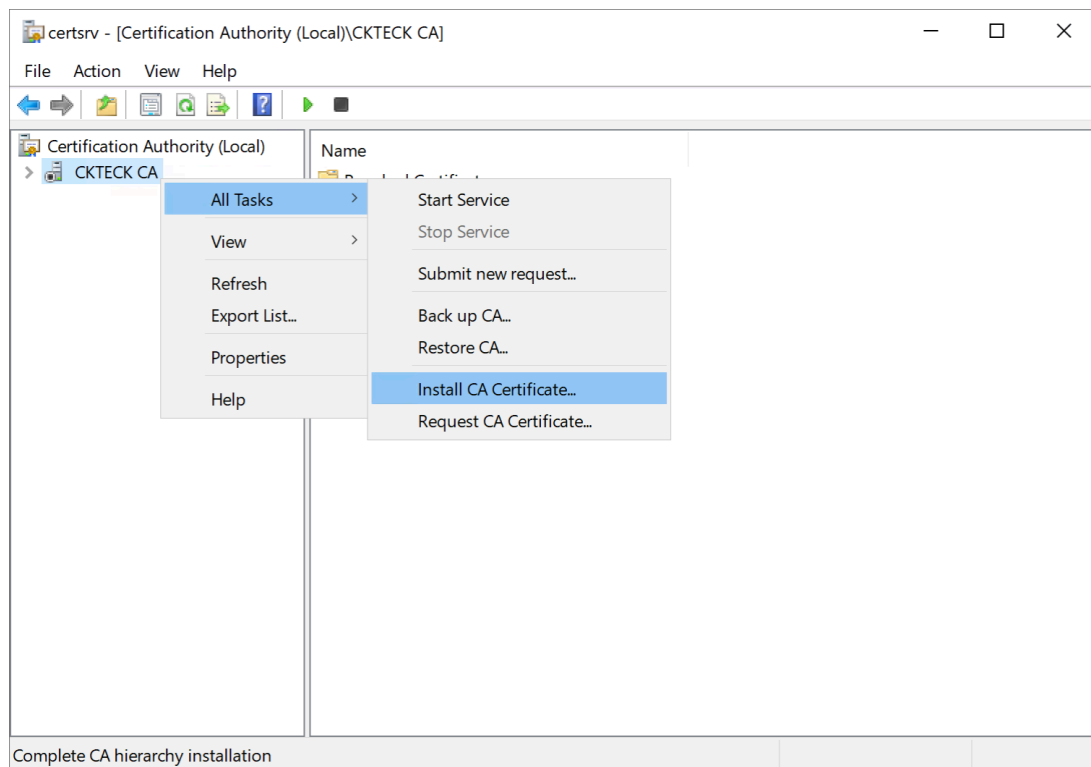


Abbildung 12: Installieren der CA-Zertifikatskette

Der nächste Schritt ist von **hoher Wichtigkeit**. Vergewissern Sie sich, dass Sie keine Schreibfehler oder ähnliches gemacht haben! Ansonsten werden im späteren Verlauf der Übung **üble Probleme** auftreten und Sie werden die Übung fast von vorne beginnen müssen!

Wichtig

Es folgt eine Vorbereitungsarbeit für das später in Angriff genommene Feature “OCSP”. Öffnen Sie dazu die Properties der CA per Rechtsklick-Kontextmenü.

Wechseln Sie in den Extensions-Tab und fügen Sie in der “**Authority Information Access**” Extension den folgenden Eintrag **auf Ihre Domäne und Hostnamen angepasst** hinzu. **Der einzutragende Host ist Ihr Windows-Server/CA-Server!**

Aktivieren Sie zudem die Option “**Include in the online certificate status protocol (OCSP) extension**”

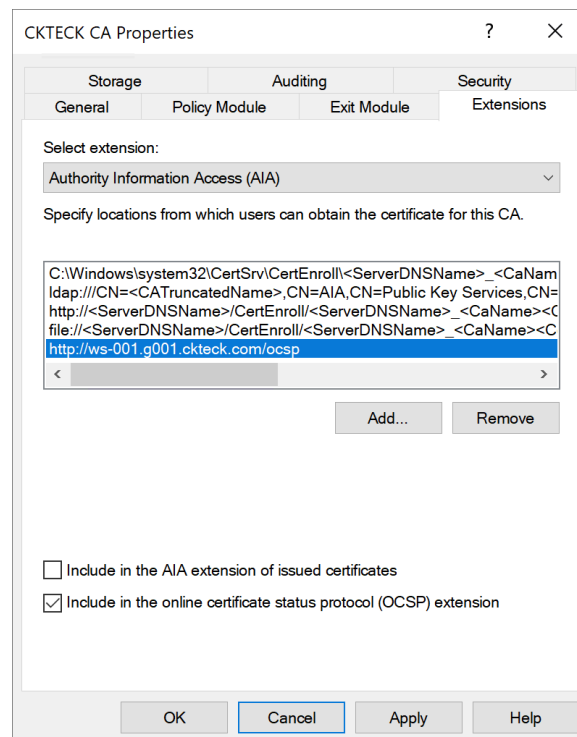


Abbildung 13: Hinzufügen einer neuen Location für Authority Information Access

KONTROLLIEREN SIE NOCHMALS, DASS SIE HOSTNAME UND GRUPPENNUMMER OBEN ANGEPASST HABEN!

http://ws-XXX.gXXX.ckteck.com/ocsp

Gönnen Sie sich die zusätzliche Freizeit, indem Sie keine Flüchtigkeitsfehler begehen und darum die Übung nicht nochmals **von vorne beginnen** müssen!

Wird bei der Eingabe der URL ein Fehler gemacht, kann im späteren Verlauf der Übung der OCSP Online Responder nicht gefunden werden. Im Nachhinein kann diese Option **NICHT** mehr angepasst werden.

Nun kann die CA gestartet werden. Dies geschieht über das gleiche Kontextmenü wie auch schon die Installation des CA-Zertifikats.

Als nächstes wird der Role Service “**Certification Authority Web Enrollment**” konfiguriert. Der Konfigurationsdialog kann auch wieder über den Server Manager aufgerufen werden.

Anpassungen an der Default-Konfiguration sind keine möglich.

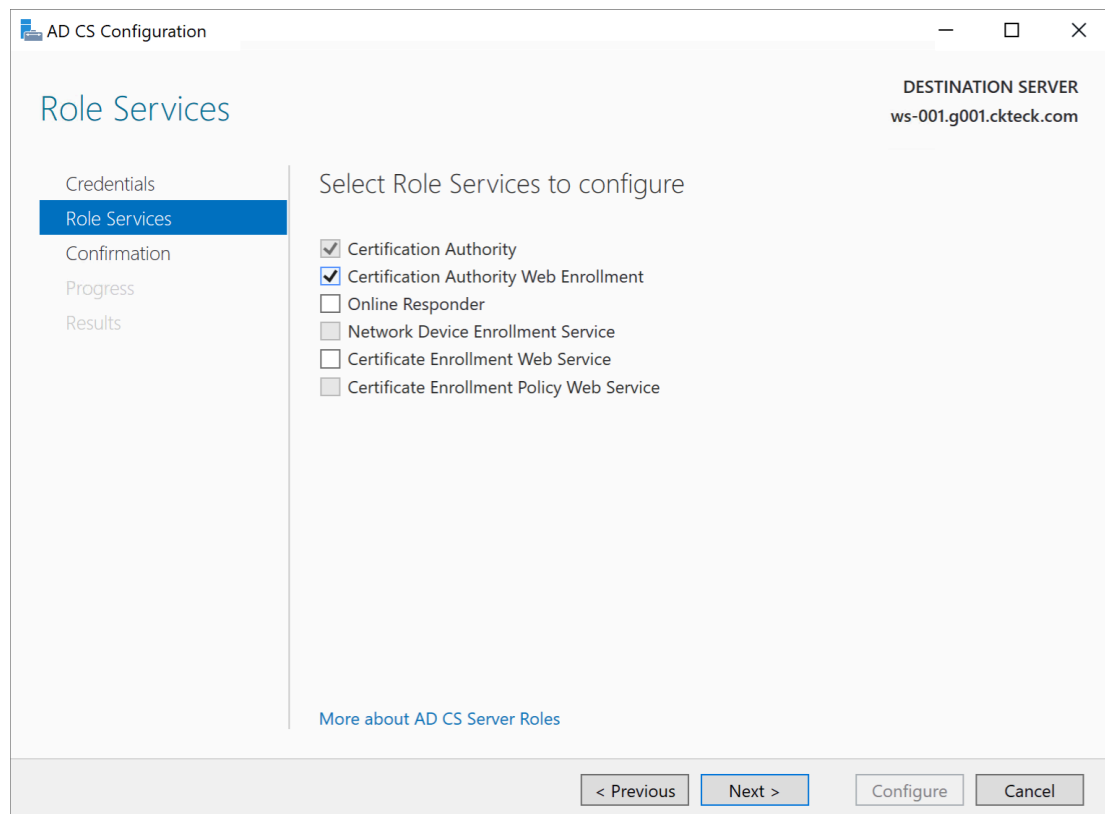


Abbildung 14: Konfiguration des Role Services “Certification Authority Web Enrollment”

Als nächstes wird der Role Service “**Certificate Enrollment Web Service**” konfiguriert.

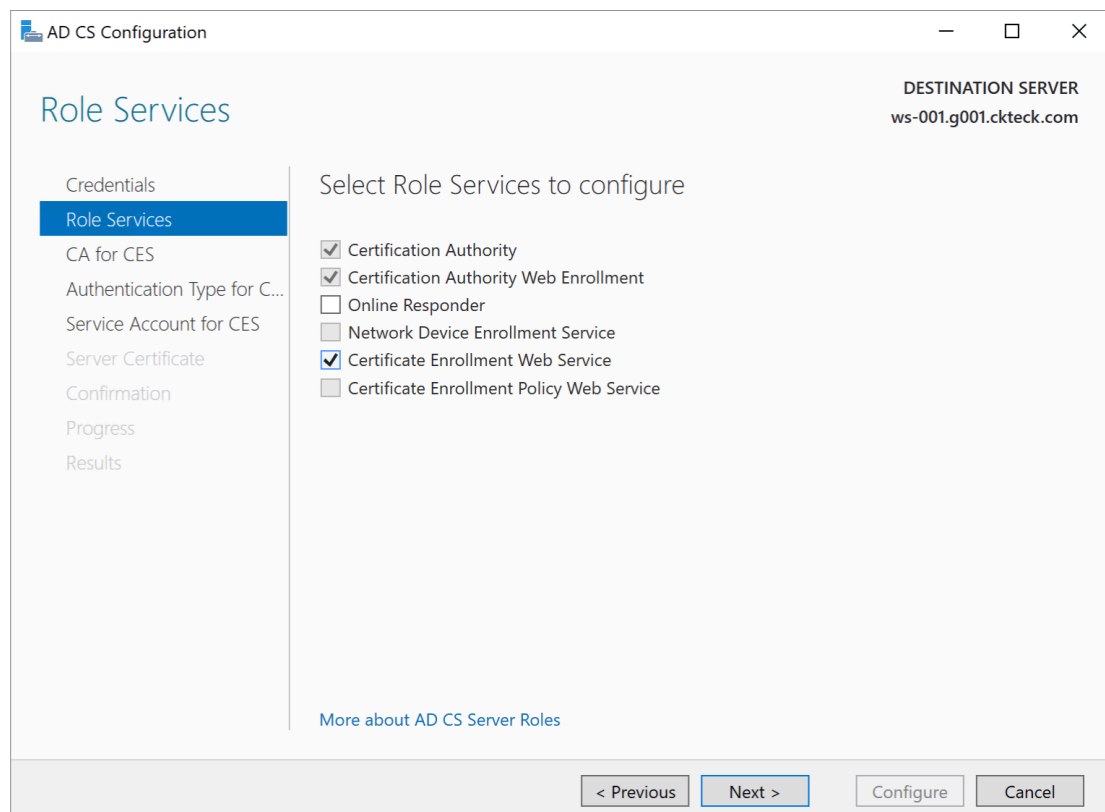


Abbildung 15: Konfiguration des Role Services “Certificate Enrollment Web Service”

Als nächstes muss die Authentifizierungsart bestimmt werden. Wir verwenden die integrierte Windows-Authentifizierung.

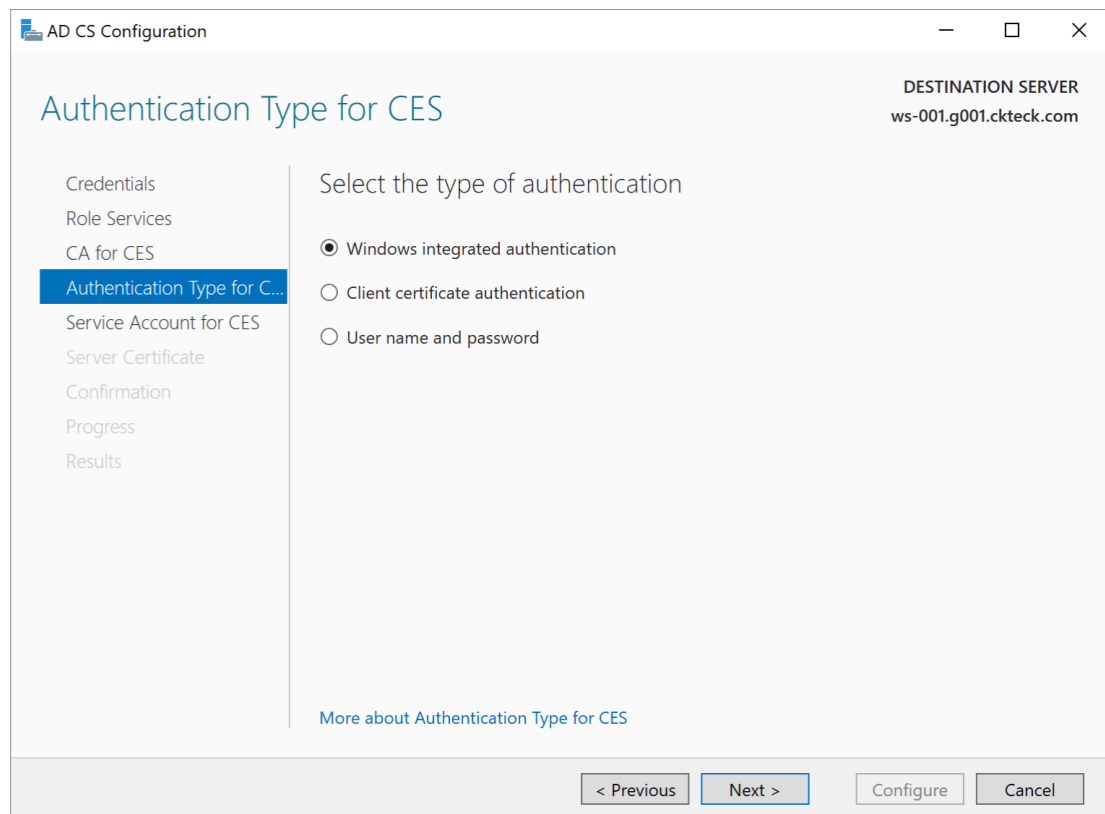


Abbildung 16: Wahl des Authentifizierungstyps

Der Webservice kann entweder mit einem Service User oder einem integrierten Account betrieben werden. Wir entscheiden uns einen Service User zu erstellen.

Wechseln Sie ins "Active Directory Users and Computers" und erstellen Sie einen User namens **cesagent** in der für Service Accounts vorgesehenen OU. Der User muss Mitglied der Gruppe **IIS_IUSRS** und lokaler Administrator sein. Verwenden Sie die Gruppe "Domain Admins" dazu. Dies ist zwar alles andere als korrekte Vergabe von Rechten, jedoch sparen wir uns die Zeit eine lokale Administratoren-Gruppe zu erstellen und lokal einzutragen.

Beachten Sie beim Erstellen, dass der Benutzer sein Passwort nicht beim nächsten Einloggen ändern muss. Das Passwort soll auch nicht ablaufen.

Wählen Sie den Account im Dialog aus und geben Sie das Passwort für den Account ein.

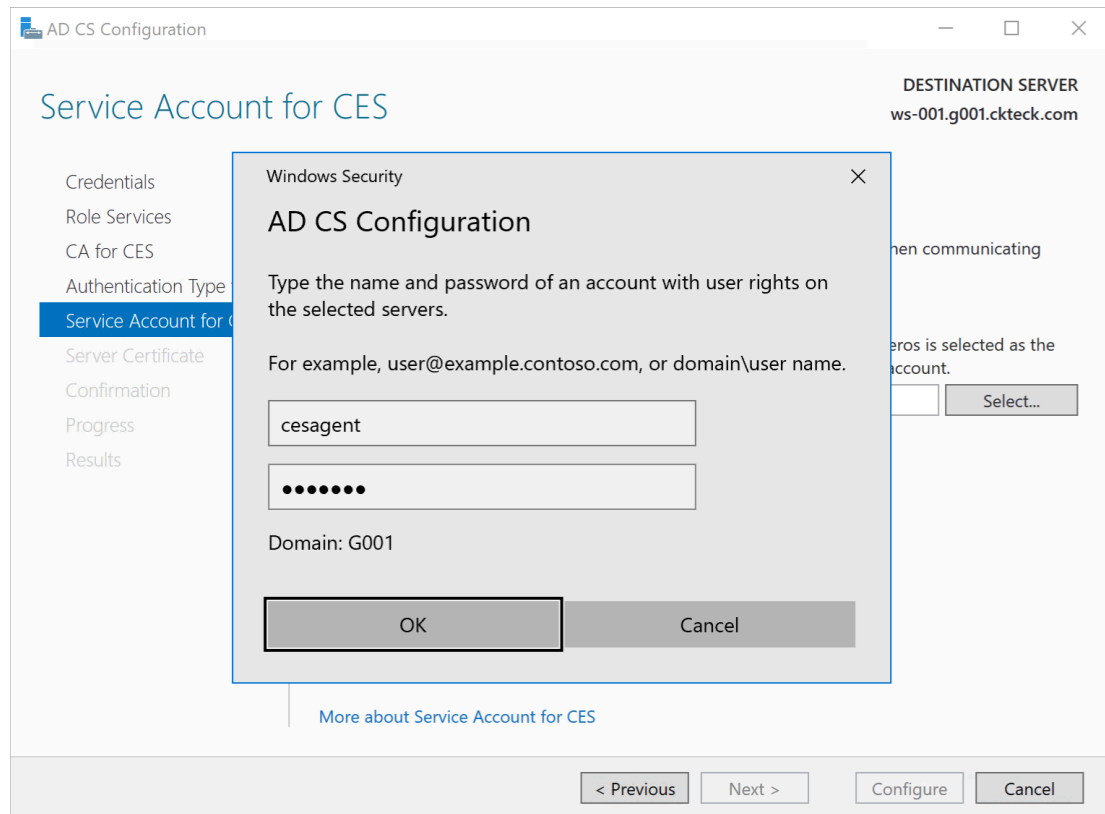


Abbildung 17: Authentifizierung des Users `cesagent`

Als nächstes muss ein Zertifikat für den Web-Service ausgewählt werden. Wir besitzen bereits eines, welches bei der Installation der CA generiert wurde. Dieses kann auch für SSL verwendet werden. Wählen Sie das bestehende Zertifikat aus.

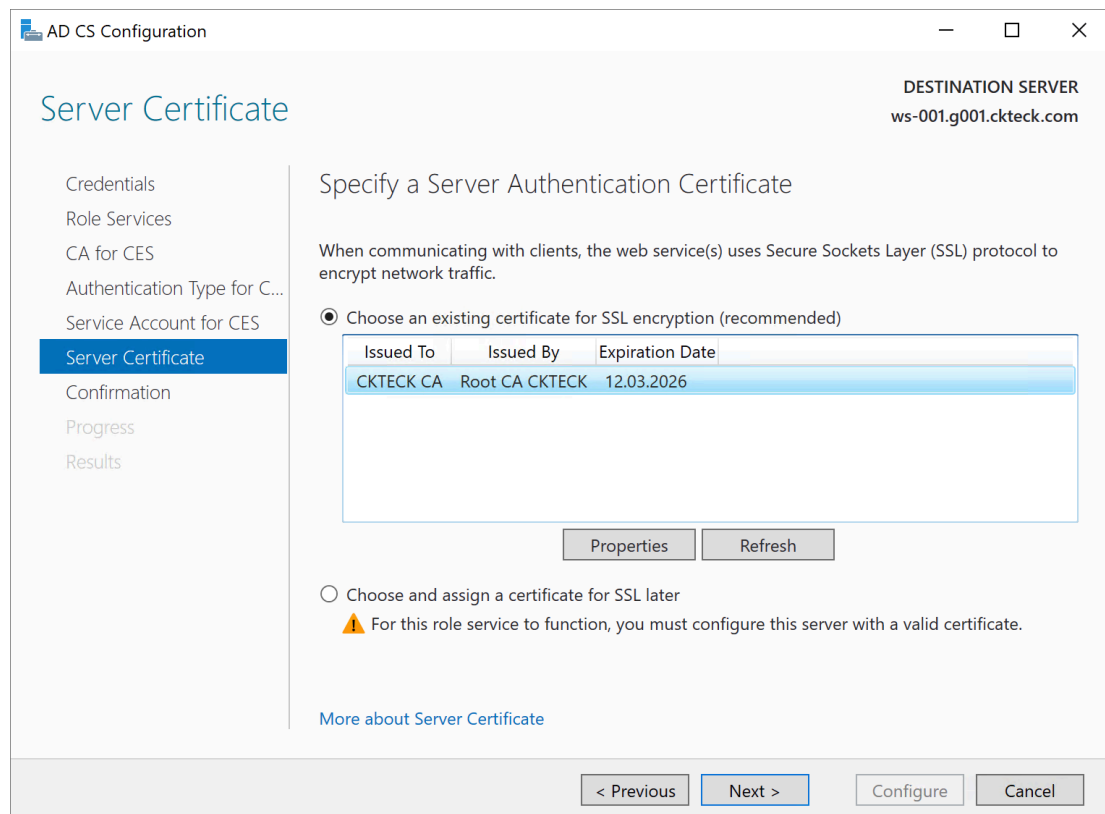


Abbildung 18: Auswahl des Zertifikats für den Web-Service

Als letzter Role Service wird der “**Online Responder**” konfiguriert. Dabei ist wieder keine spezielle Konfiguration nötig. Achten Sie darauf, dass Sie den Konfigurationsdialog abschliessen, da der Role Service ansonsten nicht konfiguriert wird und später Probleme bei der Revocation auftreten.

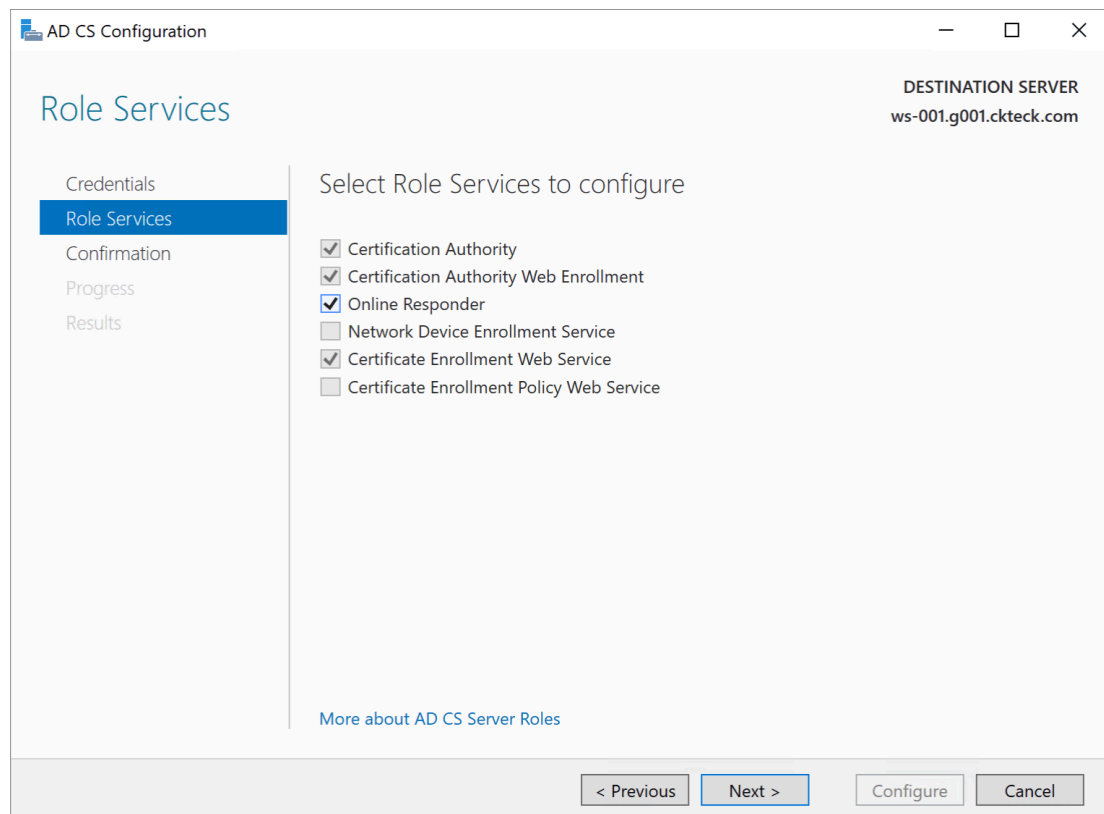


Abbildung 19: Konfiguration des Role Services “Online Responder”

Nun ist die Subordinate oder auch Intermediate Certification Authority installiert. Die Root CA, welche unser Subordinate CA Certificate ausgestellt hat, wird im Offline-Modus betrieben. Das bedeutet, dass der Server nicht an die Domäne angebunden ist. Dies hat zur Folge, dass die Domäne und ihre Mitglieder nichts über das Root Certificate der Subordinate CA wissen.

Damit die Certificate Chain sauber abgebildet werden kann, muss nun das Root CA Certificate dem Active Directory bekanntgemacht werden. Öffnen Sie dazu eine Command Prompt **als Administrator** und setzen Sie folgenden Befehl ab. Verweisen Sie dabei auf das zuvor heruntergeladene Root CA Certificate. Je nachdem wie Sie die Datei benannt und wo Sie es abgespeichert haben, verändert sich natürlich die Pfadangabe im Command.

```
1 certutil -dspublish -f C:\rootcacert.cer RootCA
```

3. HTTPS aktivieren

In diesem Kapitel wird eine bestehende Webseite im Intranet mittels Zertifikat HTTPS-fähig gemacht.

Heutzutage existiert mit Let's Encrypt eine gute Gratis-Lösung für Webserver-Zertifikate, die mit Hilfe des Let's Encrypt Bots mit wenigen Handgriffen installiert ist. In diesem Kapitel wollen wir das Zertifikat jedoch “von Hand” bei unserer CA lösen und installieren und dabei die verschiedenen kryptografischen Vorgänge identifizieren.

Wechseln Sie auf Ihren Linux-Client. Dieser dient gleichzeitig auch als unser `apache2`-Webserver.

Öffnen Sie ein Terminal und wechseln Sie zum Root-User.

Navigieren Sie anschliessend in den folgenden Ordner:

```
1 cd /etc/ssl/private/
```

In diesem Ordner werden die Private Keys aufbewahrt. Als nächstes werden Sie einen Certificate Request erstellen.

Google erzwingt seit Mai 2017, dass Zertifikate über Einträge im Zertifikatsfeld “Subject Alternative Names” verfügen müssen. Ansonsten wird das Zertifikat als invalid angezeigt. Mehr Informationen finden Sie hier:

<https://www.heise.de/hintergrund/Chrome-blockt-ab-sofort-Zertifikate-mit-Common-Name-3717594.html>

Obiger Sachverhalt heisst für uns, dass Sie zuerst ein Konfigurationsfile für Ihren Certificate Request erstellen müssen.

```
1 nano request.conf
```

Fügen Sie folgenden Inhalt in die Datei ein. **Vergessen Sie nicht wo nötig Ihre Gruppennummer / Ihre Domäne anzupassen!**

```
1 [req]
2 distinguished_name = req_distinguished_name
3 req_extensions = v3_req
4 prompt = no
5 [req_distinguished_name]
6 C = CH
7 ST = ZG
8 L = Rotkreuz
9 O = CKTECK
10 OU = Switzerland
11 CN = www.gXXX.ckteck.com
12 [v3_req]
13 keyUsage = keyEncipherment, dataEncipherment
14 extendedKeyUsage = serverAuth
15 subjectAltName = @alt_names
16 [alt_names]
17 DNS.1 = www.gXXX.ckteck.com
```

Studieren Sie den untenstehenden Command und führen Sie ihn aus. Mit der Option `-nodes` (no DES) speichern Sie den private Key unverschlüsselt. Somit werden Sie beim Starten des Webserver auch nicht nach der Passphrase für den private Key gefragt und `apache2` kann ohne Benutzerinteraktion gestartet werden. Ausserdem kann das Labor-team den Webserver starten, ohne zuerst nach dem Passwort fragen zu müssen. Weil der Private Key unverschlüsselt

abgespeichert wird, ist es unerlässlich, dass die Berechtigungen korrekt gesetzt sind. Nur der Besitzer darf die Datei lesen können.

```
1 openssl req -newkey rsa:4096 -nodes -sha256 -keyout www-private.key -out  
   www.csr -config request.conf
```

Aufgabe 3.1

Was haben Sie hier gerade generiert? Beschreiben Sie!

Hinweis

Es handelt sich um mehrere Komponenten.

Lösung

Wir haben einen Private Key und einen Certificate Signing Request generiert.

Aufgabe 3.2

Wie funktioniert so ein Certificate Signing Request? Welche Schlüssel kommen wo und für was zum Einsatz?

Hinweis

https://en.wikipedia.org/wiki/Certificate_signing_request

Lösung

Es wird ein Private Key generiert. Im CSR ist der zugehörige Public Key hinterlegt. Der CSR wird später mit dem Private Key der CA signiert. Mit dem Public Key der CA kann dann überprüft werden, ob das Zertifikat gültig ist.

Öffnen Sie nun eine Firefox-Instanz und navigieren Sie zum **Certification Authority Enrollment Web Service**. Authentifizieren Sie sich mit dem Domain Admin Account **labadmin**.

Sie finden den Enrollment Web Service unter folgender URL – ersetzen Sie Ihre Gruppennummer:

<http://gXXX.ckteck.com/certsrv>

Navigieren Sie wie folgt: **request a certificate** → **advanced certification request** → **submit a request**

Kopieren Sie nun den Inhalt der zuvor generierten **www.csr** Datei in das Saved-Request-Feld und wählen Sie **Web Server** als Certificate Template.

Microsoft Active Directory Certificate Services -- CKTECK CA [Home](#)

Submit a Certificate Request or Renewal Request

To submit a saved request to the CA, paste a base-64-encoded CMC or PKCS #10 certificate request or PKCS #7 renewal request generated by an external source (such as a Web server) in the Saved Request box.

Saved Request:

Base-64-encoded certificate request (CMC or PKCS #10 or PKCS #7):

```

xCc2+1q517Dcu1zW7pwh8s5Z+jdxKsc2ZYug5JLMwAYr
H8/+FFDNgRNGdydhcww0/qJCyHzTwBQsgmV4gfjrb:
vS1ab9zqntXFw0nvkpTB1YPb1LE0bygrAdosTMe0ag8
yjF4Y9206pUJzsH0udIeFwMQn5H16jZiB4eq6z6e4ck:
-----END CERTIFICATE REQUEST-----

```

Certificate Template:

Web Server

Additional Attributes:

Attributes:

[Submit >](#)

Abbildung 20: Webformular zur Einreichung der Zertifikatsanforderung

Lassen Sie sich ein Zertifikat generieren. Laden Sie anschliessend das [BASE64](#)-encodierte Zertifikat herunter. Öffnen Sie das Zertifikat mit dem Text-Editor **Mousepad** und kopieren Sie den Inhalt in die Zwischenablage. Wechseln Sie wieder ins Terminal.

Navigieren Sie eine Stufe hoch und wechseln Sie in den Ordner [certs](#).

```

1 cd ..
2 cd certs/

```

Erstellen Sie eine Datei namens `www.cer` und fügen Sie den zuvor in die Zwischenablage kopierten Inhalt ein. Speichern und verlassen Sie die Datei wieder.

```

1 nano www.cer

```

Nun besitzen Sie ein Webserver-Zertifikat und haben es an der korrekten Stelle abgelegt.

[apache2](#) merkt dies jedoch nicht automatisch, sondern muss noch entsprechend konfiguriert werden. Öffnen Sie dazu die [apache2](#)-SSL-Konfigurationsdatei:

```

1 nano /etc/apache2/sites-available/default-ssl.conf

```

Passen Sie die folgenden Zeilen an. Danach speichern und verlassen Sie die Datei wieder. Den Eintrag `ServerName` müssen Sie neu anlegen. Fügen Sie ihn einfach oberhalb der anderen beiden Zeilen ein. Passen Sie die URL entsprechend Ihrer Gruppennummer an.

```
1 ServerName www.gXXX.ckteck.com
2 SSLCertificateFile /etc/ssl/certs/www.cer
3 SSLCertificateKeyFile /etc/ssl/private/www-private.key
```

`apache2` unterstützt Out-of-the-Box kein SSL. Dieses Modul muss zuerst aktiviert werden. Dies geschieht mit den folgenden zwei Commands.

```
1 a2enmod ssl
2 a2ensite default-ssl
```

Nun könnte theoretisch nach einem Neustart des `apache2` Servers auf unsere Webseite mit HTTPS zugegriffen werden, jedoch ist weiterhin der Zugriff mittels HTTP möglich. Dies wollen wir verhindern. Öffnen Sie dazu die folgende Datei:

```
1 nano /etc/apache2/sites-available/000-default.conf
```

Ergänzen Sie die Datei mit dem folgenden Statement innerhalb der VirtualHost Port 80 Definition

```
1 Redirect permanent / https://www.gXXX.ckteck.com/
```

Die Konfiguration ist nun abgeschlossen. Damit diese wirksam wird, muss der `apache2`-Server neu gestartet werden.

```
1 systemctl restart apache2
```

Starten Sie zur Sicherheit Ihren Windows-Client neu bevor Sie fortfahren. Sie werden gleich erfahren wieso. Loggen Sie sich danach mit dem Benutzer `sysing01` ein.

Aufgabe 3.3

Testen Sie nun die zuvor mit HTTPS ausgerüstete Webseite (www.gXXX.ckteck.com) von Ihrem Linux-Client und Ihrem Windows Client (User `sysing01`) aus. Warum sieht bei Windows alles gut aus, während auf Ihrem Linux Gerät dem Zertifikat nicht vertraut wird?

Lösung

Das CKTECK-Root-CA-Zertifikat wird über AD an die Clients verteilt (dspublish). Bei Linux passiert dies nicht automatisch.

Wird dem Webserver-Zertifikat auf Ihrem Windows-Client nicht vertraut, müssen Sie eventuell den Windows-Client neustarten. Wird dann dem Zertifikat immer noch nicht vertraut, wird etwas mit dem AD-Publish des Zertifikats falsch gelaufen sein. Reparieren Sie etwaige Fehler bevor Sie weiterfahren.

4. Certificate Authentication

In diesem Kapitel werden Sie die Authentifizierung mit Zertifikat kennenlernen und konfigurieren.

4.1. Webserver konfigurieren

Da unsere Webseite interne Informationen beinhaltet, sollen nur Mitarbeiter mit einem gültigen Zertifikat darauf zugreifen können. Dies bietet einen guten Schutz, ohne dass die Mitarbeiter sich aktiv authentifizieren müssen.

Um dieses Feature zu nutzen, muss die Certificate Chain der Certification Authority (CA) dem Webserver bekannt sein. Gegen diese wird der Webserver die User-Zertifikate prüfen.

Die CA Certificate Chain kann im Certification Authority Enrollment Web Service heruntergeladen werden. Dies ist der gleiche Ort, wo Sie auch schon das Webserver-Zertifikat bezogen haben. Auf der Frontpage finden Sie die Option **“Download a CA certificate, certificate chain or CRL”**.

Wählen Sie **BASE64**-Encoding und laden Sie die **“CA certificate chain”** auf Ihren Linux-Client herunter. Die Chain kommt im **p7b**-Format daher. Damit unser Debian dieses lesen kann, muss es ins **PEM**-Format konvertiert werden. Vereinfacht gesagt, besteht ein **PEM**-File aus mehreren Zertifikaten, die einfach ins gleiche File kopiert wurden.

Passen Sie wo nötig Dateinamen und Pfadangaben auf Ihren Download-Ort an.

```
1 openssl pkcs7 -print_certs -in ca-chain.p7b -out /etc/ssl/certs/ckteck-ca.pem
```

Die dazu nötigen Konfigurationen des **apache2**-Servers werden in der folgenden Datei vorgenommen:

```
1 nano /etc/apache2/sites-available/default-ssl.conf
```

Kommentieren Sie folgende Zeilen aus/ergänzen und verändern Sie entsprechend. Danach speichern und verlassen Sie die Datei:

```
1 SSLCACertificateFile "/etc/ssl/certs/ckteck-ca.pem"
2 SSLVerifyClient require
3 SSLVerifyDepth 2
```

Damit die Konfigurationsänderungen wirksam werden, muss der **apache2**-Server neu gestartet werden.

```
1 systemctl restart apache2
```

Aufgabe 4.1

Versuchen Sie auf Ihrem Windows-Client die Webseite erneut aufzumachen. Sollte sich nichts verändern, sind Sie eventuell Opfer der berühmten Cache-Problematik geworden. Am einfachsten öffnen Sie bei jedem Webseiten-Test in dieser Laborübung ein neues Private-Browsing-Fenster. Dies geschieht mit der Tastenkombination CTRL + Shift + N. Eine weitere Möglichkeit ist das Löschen des Caches.

Kann auf die Webseite zugegriffen werden? Erscheint eine Meldung? Warum funktioniert der Zugriff nicht?

Lösung

Es erscheint die Meldung **ERR_BAD_SSL_CLIENT_AUTH_CERT**

Der Client scheint also kein gültiges Zertifikat zu präsentieren. Auf Serverseite wird dieses Clientzertifikat nun erfordert.

Aufgabe 4.2

Beschreiben Sie den Kommunikationsablauf zwischen Client und Webserver bei zertifikatsbasierter Authentifizierung.

Hinweis: **Anhang B – Zertifikatsbasierte, gegenseitige Authentifizierung** könnte hilfreich sein.

Lösung

Server und Client präsentieren gegenseitig ihre Zertifikate.

Der Server prüft das Zertifikat des Clients, der Client prüft das Zertifikat des Servers.

Stimmt alles kann die Verbindung hergestellt werden.

4.2. User Certificate Autoenrollment

Der Zugriff auf die Webseite funktioniert nicht mehr, weil der eingeloggte User kein Zertifikat besitzt. Man könnte nun analog zum HTTPS-Kapitel ein Certificate Request erstellen und vom Certification Authority Enrollment Web Service ein Zertifikat anfordern. Jedoch ist das vom Otto Normaluser zu viel verlangt und zu aufwendig, diesen Arbeitsschritt durch einen IT-Mitarbeiter bei jedem Benutzer durchführen zu lassen.

Abhilfe schafft das Autoenrollment-Feature. Dieses erlaubt es, Zertifikate in einer Windows-Domäne automatisiert an die berechtigten User zu verteilen.

4.2.1. Certificate Template erstellen

Wechseln Sie wieder auf Ihren Windows-Server und öffnen Sie den **Certification Authority**-Konfigurationsdialog.

Öffnen Sie das Kontextmenü des Eintrags **“Certificate Templates”** mittels Rechtsklick und wählen Sie **“Manage”**.

Suchen Sie nach dem vordefinierten Template **“User”** und erstellen Sie eine Kopie davon mit dem Kontextmenü-Eintrag **“Duplicate”**.

Vergeben Sie dem Template einen Namen und fügen Sie im Tab Security die Gruppe **“Domain Users”** hinzu. Diese soll die folgenden Berechtigungen erhalten:

Properties of New Template

Subject Name | Server | Issuance Requirements

Superseded Templates | Extensions | Security

Compatibility | General | Request Handling | Cryptography | Key Attestation

Template display name:
company User

Template name:
companyUser

Validity period: 1 years | Renewal period: 6 weeks

☒ Publish certificate in Active Directory
☐ Do not automatically reenroll if a duplicate certificate exists in Active Directory

OK | Cancel | Apply | Help

Properties of New Template

Subject Name | Server | Issuance Requirements

Compatibility | General | Request Handling | Cryptography | Key Attestation

Superseded Templates | Extensions | Security

Group or user names:

- Authenticated Users
- labadmin (labadmin@g001.ckteck.com)
- Domain Admins (G001\Domain Admins)
- Domain Users (G001\Domain Users)
- Enterprise Admins (G001\Enterprise Admins)

Add... Remove

Permissions for Domain Users

	Allow	Deny
Full Control	☐	☐
Read	☒	☐
Write	☐	☐
Enroll	☒	☐
Autoenroll	☒	☐

For special permissions or advanced settings, click Advanced.

Advanced

OK | Cancel | Apply | Help

Speichern Sie Ihr neues Template und kehren Sie in den Certification Authority Dialog zurück.

Nun ist ein neues Template für User Zertifikate erstellt, es ist jedoch noch nicht aktiv.

Öffnen Sie das Kontextmenü des Eintrages “**Certificate Templates**” erneut und klicken Sie auf “**new**” → “**Certificate Template to issue...**”

Wählen Sie Ihr neu erstelltes Template aus.

4.2.2. GPO konfigurieren

Um die Konfiguration zu vervollständigen, muss eine GPO konfiguriert werden, die den Domänen-Clients mitteilt, dass Autoenrollment für Zertifikate verwendet werden soll.

Öffnen Sie das **Group Policy Management**.

Erstellen Sie eine neue GPO auf dem **Switzerland** Ordner, damit alle Mitarbeiter (auch Admins) von der GPO betroffen sind und verlinken Sie diese darauf. Verwenden Sie einen sprechenden Namen für Ihre GPO.

Editieren Sie das erstellte Objekt und navigieren Sie in der GPO-Baumstruktur an folgenden Ort:

User Configuration → **Policies** → **Windows Settings** → **Security Settings** → **Public Key Policies**

Die für uns spannende Einstellung heisst “**Certificate Services Client -- Auto-Enrollment**”

Konfigurieren Sie diese wie folgt:

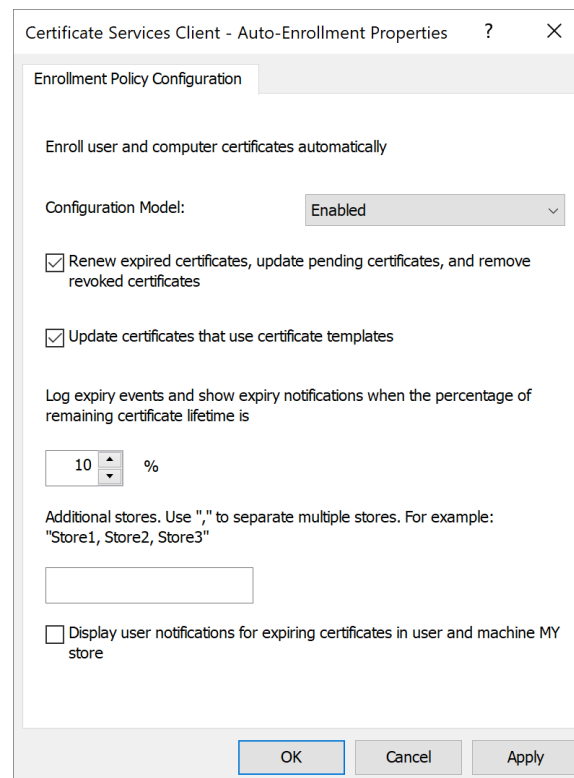


Abbildung 21: Auto-Enrollment-Einstellungen

Melden Sie sich nun mit dem Domain-User vom Windows-Client ab und wieder neu an. Versuchen Sie nun unsere Webseite nochmals zu öffnen.

Die Webseite kann nun nach erfolgreicher Authentifizierung mit Zertifikat geöffnet werden. Teils muss auch nochmals aktualisiert werden – wegen der Browser-Caching-Funktion.

Wechseln Sie wieder in den “**Certification Authority**”-Dialog und schauen Sie sich das soeben ausgestellte Zertifikat unter “**Issued Certificates**” an.

Aufgabe 4.3

Wechseln Sie in den Tab “Details”. Für welche Zwecke kann dieses Zertifikat alles verwendet werden?

Lösung

Digital Signature, Key Encipherment (a0)

4.3. Certificate Revocation

Stellen Sie sich vor, dass Sie in der IT-Abteilung eines mittelständischen Unternehmens arbeiten und die Verwaltung von Benutzerkonten zu Ihren Routineaufgaben gehört. Wenn Mitarbeitende das Unternehmen verlassen, sperren Sie standardmässig ihre Windows-Accounts, um den Zugriff auf Unternehmensdaten zu unterbinden.

Eine Herausforderung entsteht jedoch, wenn zuvor eine zertifikatsbasierte Authentifizierung eingerichtet wurde. Diese **Zertifikate funktionieren unabhängig von den Windows-Anmeldedaten** und haben typischerweise eine Gültigkeitsdauer von einem Jahr. Im ungünstigsten Fall könnte ein ausgeschiedener Mitarbeitender somit noch bis zu einem Jahr lang über sein Zertifikat Zugriff auf Unternehmenssysteme haben.

Um dieses Sicherheitsrisiko zu minimieren, benötigen wir einen Mechanismus zum Widerrufen von Zertifikaten. Eine bewährte Lösung bieten Certificate Revocation Lists (CRL). Sobald ein Zertifikat für ungültig erklärt wird, erfolgt ein entsprechender Eintrag in der CRL. Bei jeder Authentifizierungsanfrage wird diese Liste konsultiert und sequentiell überprüft, ob das vom Client übermittelte Zertifikat darin aufgeführt ist.

Aufgabe 4.4

Wieso könnte die oben beschriebene Funktionsweise von CRLs bei hoher Fluktuation innerhalb der Firma zu Problemen führen?

Lösung

Sehr grosse CRLs können das System verlangsamen. OCSP ist eine mögliche Lösung dafür.

Um das obige Problem zu umgehen, wurde eine neue Methode eingeführt: Online Certificate Status Protocol, kurz OCSP. Dieses funktioniert nach dem Client-Server-Prinzip, wobei der Webserver jeweils die Issuing CA nach der Gültigkeit des übermittelten Zertifikats abfragt.

4.3.1. OCSP konfigurieren

Wechseln Sie wieder in den **Certification Authority** Dialog auf Ihrem Windows-Server.

Öffnen Sie das Kontextmenü von **“Revoked Certificates”** und publizieren Sie die für ungültig erklärten Zertifikate manuell. Momentan sind das noch keine, es wird jedoch eine initiale, leere Certificate Revocation List (CRL) generiert.

Öffnen Sie wieder das Kontextmenü der **“Certificate Templates”** und wählen Sie **“Manage”**.

Als nächstes muss das Template **“OCSP Response Signing”** dupliziert werden. Dies geschieht analog zum User-Zertifikat.

Im Tab **“Security”** muss das Computerobjekt des Online Responders hinzugefügt werden (in unserem Fall der Domain Controller). Würde der Online Responder auf einem anderen Server installiert (grundsätzlich empfohlen), müsste dasjenige Computerobjekt hinzugefügt werden.

Hinweis

Damit das Computerobjekt gefunden werden kann, müssen Computerobjekte im Dialog **“Object Types...”** hinzugefügt werden.

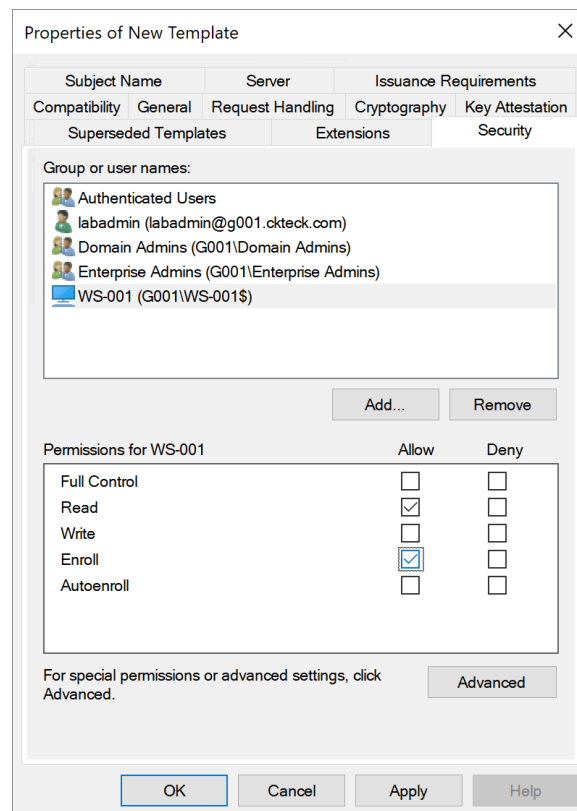


Abbildung 22: Hinzufügen des Domain Controllers zur Zertifikatsvorlage

Aktivieren Sie das neu erstellte Template über das Kontextmenü der Certificate Templates mittels **new** → **Certificate Template to issue....**

Als nächstes muss der Online Responder konfiguriert werden. Das dazu benötigte Tool befindet sich ebenfalls in den **“Windows Administrative Tools”** und nennt sich **“Online Responder Management”**.

Erstellen Sie eine neue Revocation Configuration über das Kontextmenü der **“Revocation Configuration”**. Da sich die Certification Authority auf demselben Computer und in derselben Domäne befindet, wird der Radio Button **“Existing enterprise CA”** ausgewählt.

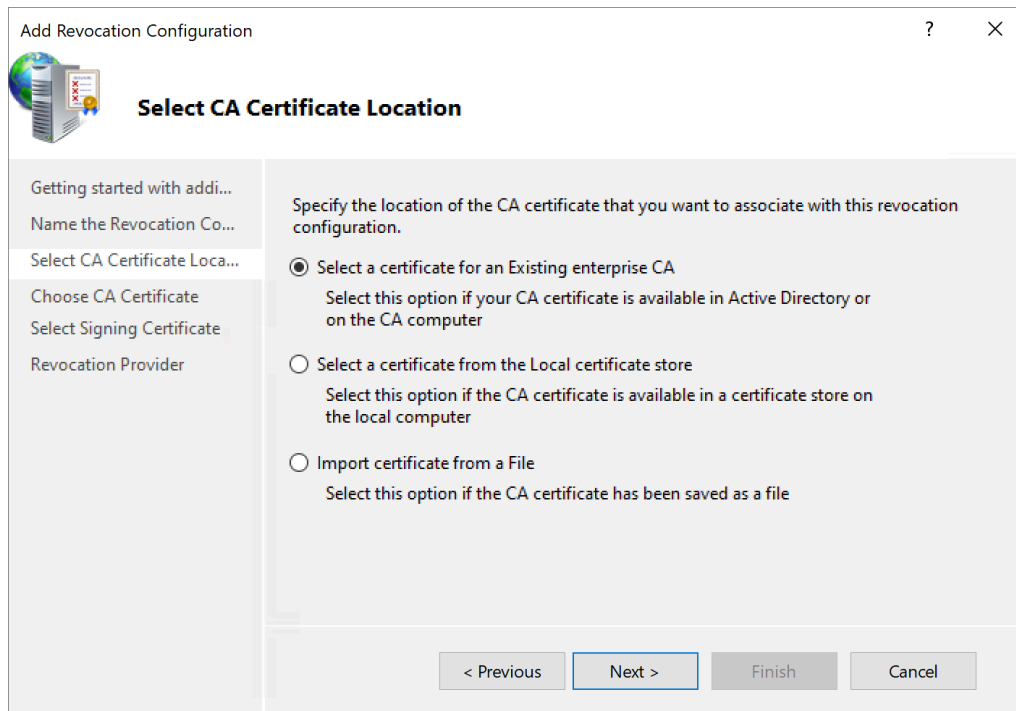


Abbildung 23: Assistent zur Erstellung einer neuen Revocation Configuration

Wählen Sie über die Browse-Funktion das bestehende CA Certificate aus.

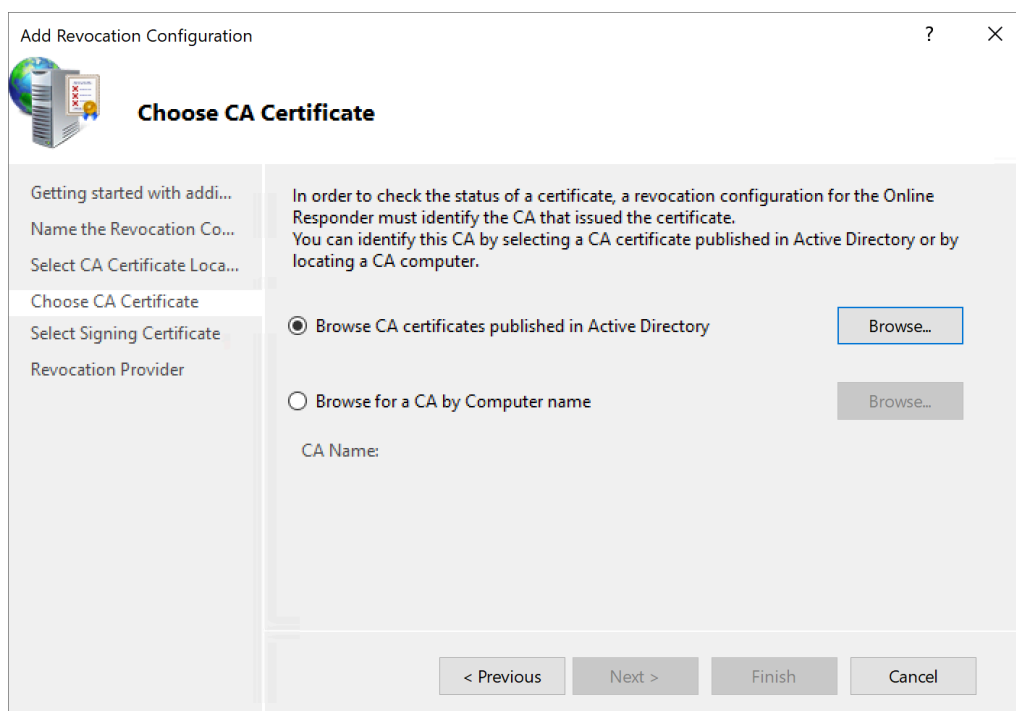


Abbildung 24: Auswählen des bestehenden CA Certificates

Überprüfen Sie, dass das zuvor erstellte Certificate Template ausgewählt ist. Dies sollte automatisch geschehen.

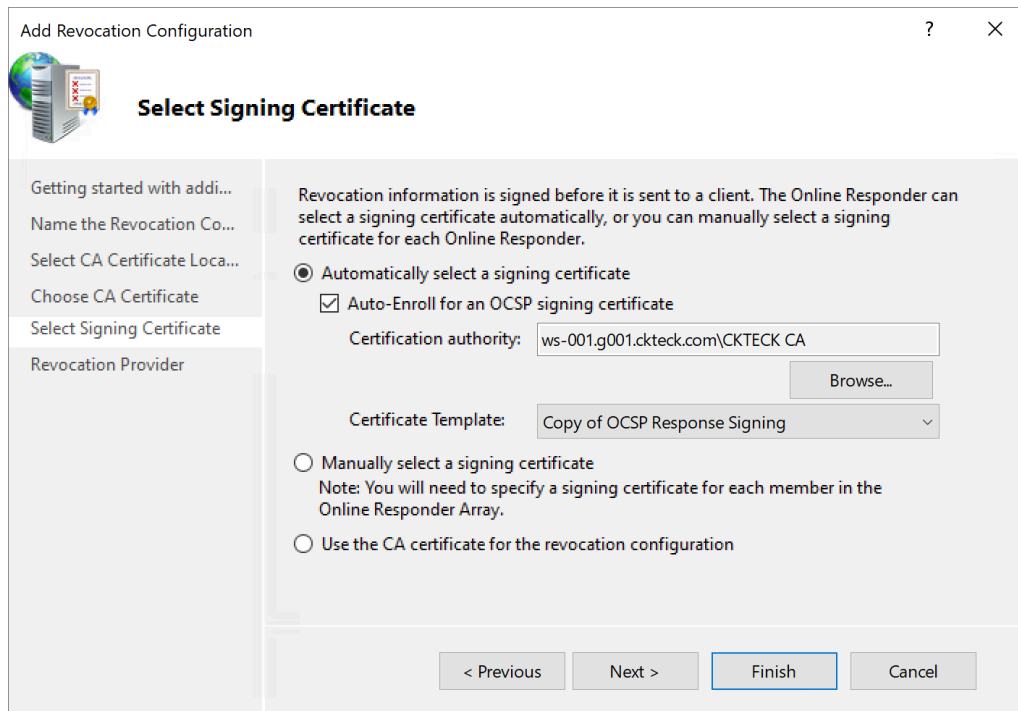


Abbildung 25: Automatische Auswahl des Zertifikats mit aktivierter Auto-Enrollment-Funktion für OCSP

Öffnen Sie die Properties der Revocation Configuration und wechseln Sie in den Tab "**Signing**". Aktivieren Sie dort den "**NONCE extension support**".

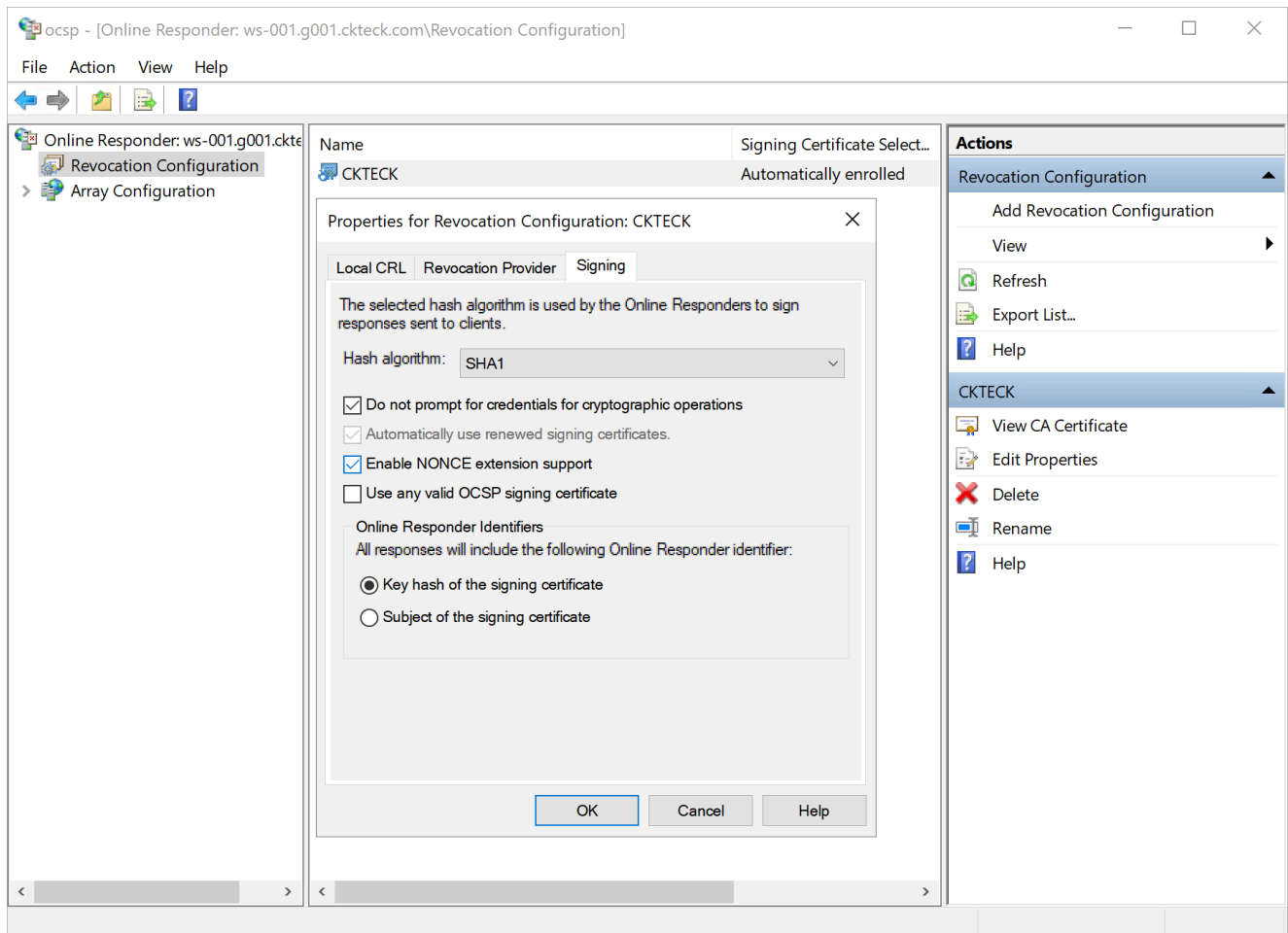


Abbildung 26: Aktivieren des “NONCE extension support” in den Revocation Configuration Properties

Aufgabe 4.5

Was hat die OCSP NONCE Extension für eine Funktion?

Hinweis

Der Wikipedia-Artikel über OCSP könnte Ihnen weiterhelfen.

https://en.wikipedia.org/wiki/Online_Certificate_Status_Protocol

Lösung

Die OCSP Nonce ist eine **Sicherheitsfunktion** des Online Certificate Status Protocol, **die durch Übermittlung eines zufällig generierten Wertes bei jeder Anfrage sogenannte Replay-Angriffe verhindert.**

Dieser einmalige Wert, der zuvor vom Server bereitgestellt wurde, stellt sicher, dass die OCSP-Antwort speziell für die aktuelle Anfrage generiert wurde und nicht von einem Angreifer wiederverwendet werden kann.

Da der [apache2](#)-Webserver in der Default-Konfiguration die NONCE Extension verlangt, muss diese im Windows Online Responder aktiviert werden. Ansonsten funktioniert die Kommunikation nicht korrekt.

Folgender Artikel zeigt Ihnen, wie Sie auch seitens Webserver die NONCE Extension ausschalten könnten: https://httpd.apache.org/docs/trunk/mod/mod_ssl.html#sslscspuserequestnonce

Laden Sie die Revocation Data über das Kontextmenü der Array Configuration neu.

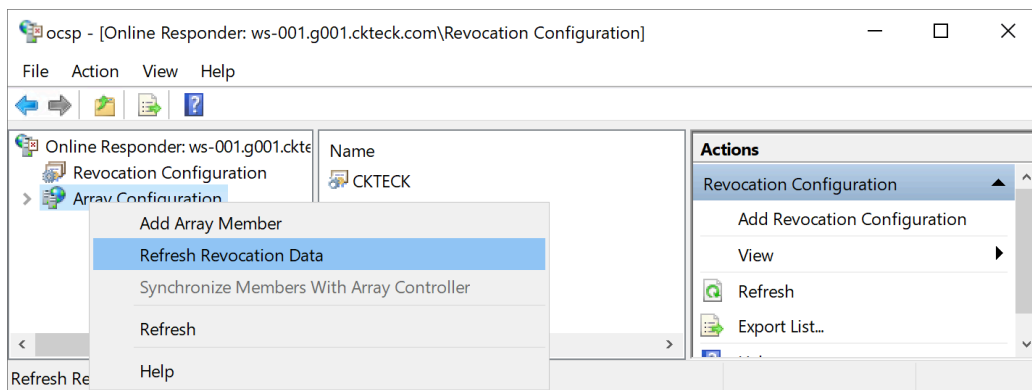


Abbildung 27: Kontextmenü “Refresh Revocation Data” in der Online-Responder-Verwaltung

Überprüfen Sie die durchgeführte Konfiguration mittels des Tools **pkiview.msc**. Geben Sie dazu **pkiview.msc** in ein “Ausführen...”-Fenster (Windows+R) ein. Alle Werte sollten “OK” sein. Warnungen mit Status “**Expiring**”, bei denen das Ablaufdatum in der Zukunft liegt, sind unkritisch und werden sich automatisch beheben, sobald die neue CRL aktualisiert wird.

4.3.2. Webserver für OCSP konfigurieren

Nun muss noch dem Webserver mitgeteilt werden, dass er die Gültigkeit von Zertifikaten mittels OCSP prüfen soll.

Um die komplette Certificate Chain prüfen zu können, muss die Certificate Chain dem **apache2**-Webserver bekannt gegeben werden. Dies haben Sie bereits **früher in dieser Übung gemacht**. Sie erinnern sich daran, wie Sie die **p7b**-Zertifikatskette in das **PEM**-Format umgewandelt haben etc.

Als nächstes muss die Konfiguration des **apache2**-Webservers angepasst werden. Öffnen Sie dazu erneut die folgende Datei auf Ihrem Linux-Client.

```
1 sudo nano /etc/apache2/sites-available/default-ssl.conf
```

Fügen Sie die folgenden Einträge ein. Die Commands befinden sich nicht als Vorlage in der Konfigurationsdatei und müssen selbst ergänzt werden.

```
1 SSLOCSPEnable on
2 SSLOCSPDefaultResponder http://ws-XXX.gXXX.ckteck.com/ocsp
3 SSLOCSPUseRequestNonce on
```

Starten Sie als letztes den **apache2**-Webserver neu, damit die Konfiguration wirksam wird. Mittlerweile kennen Sie wahrscheinlich den Befehl bereits auswendig.

4.3.3. Revocation testen

Wechseln Sie nun zurück in den Certification Authority Dialog und wechseln Sie zu Issued Certificates. Erklären Sie mittels Kontextmenü (All Tasks → Revoke Certificate) das zuvor für den User Account **sysing01** ausgestellte Zertifikat per sofort für ungültig.

Publizieren Sie nochmals die CRL-Liste durch Rechtsklick auf “Revoked Certificates” → All Tasks → Publish. Dies würde in bestimmten Intervallen auch automatisch passieren, jedoch kann die Aktualisierung auch manuell getriggert werden, um weniger lange zu warten.

Öffnen Sie auch nochmals das Online Responder Management und aktualisieren Sie die Revocation Data mittels Rechtsklick auf “Array Configuration”. Dies würde auch automatisch geschehen – wir beschleunigen die Sache nur ein wenig.

Wechseln Sie zum Windows-Client. Vergewissern Sie sich, dass der Cache Ihres Browsers geleert wurde. Ansonsten ist es gut möglich, dass Ihnen vom Browser eine lokal gecachte Version der Webseite angezeigt wird. Versuchen Sie die geschützte Webseite nochmals zu öffnen.

Aufgabe 4.6

Was ist nun passiert? Können Sie sich weiterhin die Webseite anzeigen lassen?

Öffnen Sie den `apache2` Error Log und sehen Sie sich die Meldungen darin an (zu finden unter `/var/log/apache2/error.log`).

Welche Meldung weist darauf hin, dass das vom Webserver erhaltene Zertifikat nicht mehr gültig ist?

Lösung

Die Webseite kann nicht mehr angezeigt werden. Auf dem Client erscheint der Fehler: `ERR_CONNECTION_RESET`.

Im `apache2`-Log erscheint die Meldung: “Certificate Verification: Error (23): certificate revoked”

5. Code Signing

Um die Herkunft und Integrität kompilierter Software nachzuweisen, kann diese mit einem Zertifikat digital signiert werden. Viele Softwarehersteller verwenden bereits Signaturen, doch zahlreiche Anwendungen werden noch immer unsigniert verbreitet. Ohne Signatur können bösartige Modifikationen durch Dritte unbemerkt an einer Software vorgenommen werden. Besonders gefährdet sind populäre Open-Source-Anwendungen, die frei im Internet zur Verfügung stehen.

Für die Signierung im öffentlichen Internet müssen global anerkannte Zertifikate verwendet werden. Die lokal von unserer PKI ausgestellten Zertifikate sind im “Grossen Bösen Internet” (GBI) nicht bekannt und daher nicht vertrauenswürdig. Die grundlegenden Sicherheitsmechanismen sind jedoch identisch.

In der folgenden Übung werden Sie ein PowerShell-Script signieren. Auch Scripts können digital signiert und somit vor unbemerkten Manipulationen geschützt werden.

5.1. Standardverhalten von PowerShell-Scripts

Loggen Sie sich mit dem Benutzer **sysing01** am Windows-Client ein.

Erstellen Sie auf dem Desktop eine neue Textdatei und ändern Sie die Endung der Datei auf **.ps1**, um diese als PowerShell-Script zu deklarieren.

Hinweis

Falls Sie die Endungen der Dateien nicht sehen können, ist das ein Microsoft-Feature namens “**Hide extensions for known file types**”. Da dieses Feature jedoch alles andere als hilfreich ist, wird empfohlen dieses in den Ordneroptionen auszuschalten.

Fügen Sie folgendes kleines Script in die erstellte **.ps1**-Datei ein, passen Sie Ihre Gruppennummer an und speichern Sie die Änderungen.

```
1 $wshShell = New-Object -comObject WScript.Shell
2 $shortcut = $wshShell.CreateShortcut($env:HOMEPATH+"\Desktop\Intranet.lnk")
3 $shortcut.TargetPath = "https://www.gXXX.ckteck.com/"
4 $shortcut.Save()
```

Aufgabe 5.1

Was macht das Script? Was erwarten Sie als Resultat, wenn das Script ausgeführt wurde?

Öffnen Sie eine PowerShell Console. Führen Sie das Script aus.

Funktioniert das Script? / Was für eine Meldung tritt auf?

Lösung

Das Skript erstellt auf dem Desktop eine Verknüpfung namens Intranet, welche auf den Webserver zeigt.

Es erscheint eine Meldung, ob die ExecutionPolicy angepasst werden soll.

Wie Sie in der Fehlermeldung lesen können, hat das Problem etwas mit Execution Policies zu tun. PowerShell kennt fünf verschiedene Execution Policies. Machen Sie sich mit Hilfe der folgenden Webseite mit den möglichen Execution

Policies vertraut und beschreiben Sie kurz deren Unterschiede:

https://docs.microsoft.com/de-de/powershell/module/microsoft.powershell.core/about/about_execution_policies?view=powershell-7.5

Aufgabe 5.2

Restricted:

Lösung

Standard Ausführungsrichtlinie. Erlaubt keine Skripte. Einzelne Befehle können manuell in der Konsole ausgeführt werden.

Aufgabe 5.3

AllSigned:

Lösung

Skripte können nur ausgeführt werden, wenn sie von einem vertrauenswürdigen Herausgeber digital signiert sind. Gilt für alle Skripte.

Aufgabe 5.4

RemoteSigned:

Lösung

Skripte, die aus dem Internet kommen, müssen signiert sein, während lokal gespeicherte Skripte auch ohne Signatur ausgeführt werden können.

Aufgabe 5.5

Unrestricted:

Lösung

Erlaubt die Ausführung jedes Skripts, egal ob signiert oder nicht.

Aufgabe 5.6

Bypass:

Lösung

Diese Richtlinie umgeht alle Ausführungsrichtlinien und führt alle Skript ohne Warnung oder Aufforderung aus.

Lesen Sie die aktuell angewendete Execution Policy mit folgendem Commandlet aus:

```
1 Get-ExecutionPolicy
```

Hinweis

Übrigens: Mittels Rechtsklick → “Run with Powershell” wird die Bypass-Ausführungsrichtlinie temporär für die aktuelle Sitzung (die laufende PowerShell- Prozessinstanz) aktiviert, ohne die grundlegende Ausführungsrichtlinie für Computer oder Benutzer zu verändern. Sie könnten dadurch Ihr Script bereits jetzt trotz der restriktiven ExecutionPolicy starten – verzichten Sie jedoch im Rahmen dieser Übung vorerst darauf.

5.2. Execution Policy anpassen

Ihr Systemadministrator sieht nach einem verbalen Schlagabtausch beim Kaffee ein, dass Sie als PowerShell-Developer Scripts auf Ihrem lokalen Arbeitsgerät ausführen müssen. Da Ihre Scripts aber später in der ganzen Organisation verteilt und ausgeführt werden, muss eine langfristige und sicherheitstechnisch saubere Lösung her.

Damit nur Scripts ausgeführt werden können, welche aus vertrauenswürdigen Quellen stammen (eigene Entwickler), wird die Execution Policy “**AllSigned**” gewählt.

Damit alle Computer in der ganzen Unternehmung zentral umgeschaltet werden können, wird die Änderung über das Group Policy Management des Active Directories realisiert.

Öffnen Sie das **Group Policy Management** und überlegen Sie sich, ob Sie eine bestehende GPO verwenden oder eine neue anlegen wollen. Überlegen Sie auch, auf welche OU Sie die GPO applizieren wollen.

Setzen Sie Ihre Überlegungen um.

Aktivieren Sie in der GPO die folgende Einstellung:

Computer Configuration → Policies → Administrative Templates → Windows Components → Windows PowerShell → Turn on Script Execution

Wählen Sie “**Allow only signed scripts**”.

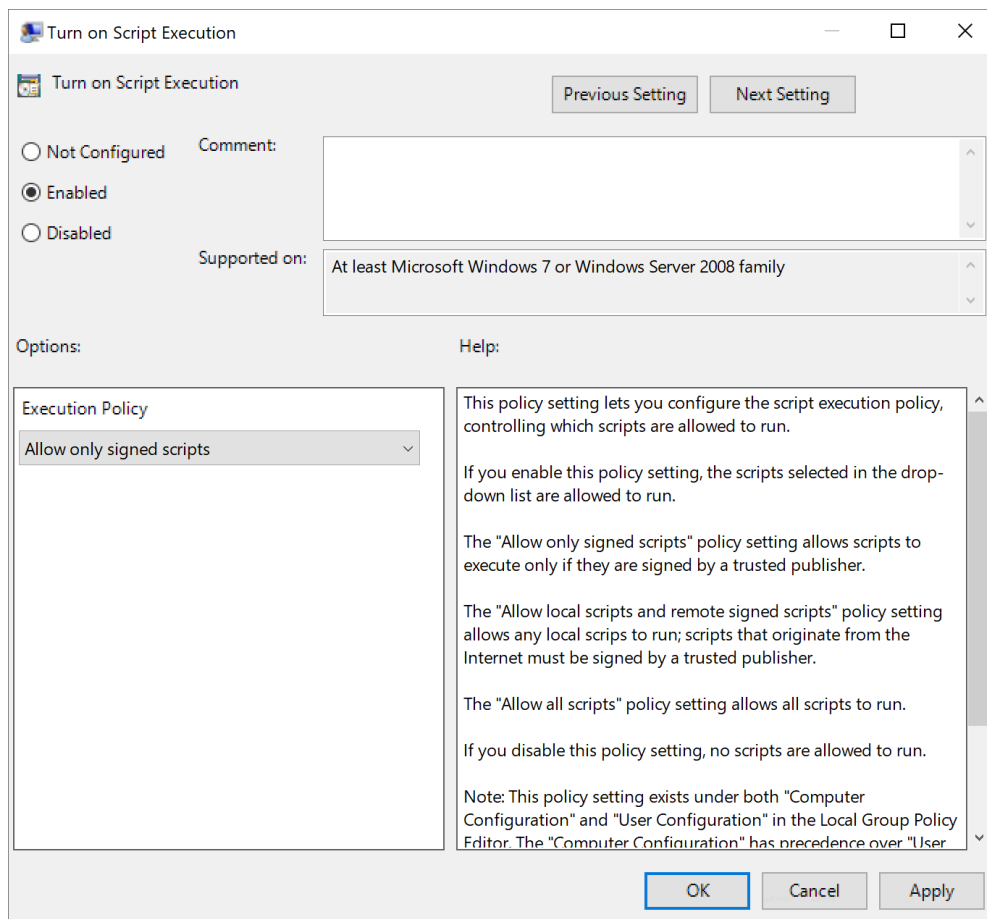


Abbildung 28: Anpassen der Script Execution Policy

Da es sich um eine Einstellung auf Computer-Ebene handelt, muss der Computer neugestartet werden, damit die Änderung wirksam wird.

Überprüfen Sie nach dem Neustart nochmals die Execution Policy und vergewissern Sie sich, dass diese den korrekten Wert vorweist.

```
1 Get-ExecutionPolicy
```

Aufgabe 5.7

Führen Sie nochmals das zuvor erstellte PowerShell Script aus. Was für eine Meldung erscheint nun?

Lösung

```
1 [...] cannot be loaded. The file [...] is not digitally signed.
```

Die Execution Policy sollte nun auf `AllSigned` gestellt sein.

5.3. Code-Signing-Zertifikate ausstellen

Grundsätzlich gibt es zwei Möglichkeiten Code Signing zu betreiben. Crypt32 beschreibt diese auf serverfault.com (eine Schwesterseite von stackoverflow.com) wie folgt:

1. Issue a personal signing certificate to each developer. Assign CodeSigning certificate template to CA and grant permissions to dev group.

pros: each developer has his own signing certificate.

cons: too many certificates. May be ok for internal (development and testing) purposes only. Is not suitable when you deliver signed binaries to your customers or other 3rd parties.

2. Issue a single certificate to developer groups. Export to PFX and provide a copy of this certificate to all devs.

pros: only one certificate is used for signing. Best suitable to sign binaries for external parties.

cons: you are not controlling who signed the file. You see it is signed by a particular certificate, but can't tell who exactly signed the file. It is security degradation.

as per best practices, products for external parties shall be signed by a single and authorized digital certificate that identifies the company. This certificate shall not have copies and should be stored in a secure container, for example smart cards. However, for internal use and if your policy allows this, I would go with option 1, to issue personalized code signing certificates to each developer.

Quelle: <https://serverfault.com/questions/679334/enterprise-root-ca-create-codesigning-certificate-for-multiple-users>

Wir werden in diesem Versuch mit Variante 1: persönliche Code-Signing-Zertifikate arbeiten.

Wechseln Sie auf den Windows-Server.

Damit das Script signiert werden kann, muss zuerst ein Code-Signing-Zertifikat erlangt werden. Dieses wird auf ähnliche Weise wie die anderen in diesem Versuch ausgestellten Zertifikaten gemacht.

Das heisst, es wird wiederum eine Gruppe benötigt, welcher es erlaubt ist, ein solches Zertifikat zu erlangen. Erstellen Sie dazu eine neue Gruppe im Active Directory mit dem Namen "**GG_CH_Codesigners**". Wie Sie das machen, haben Sie bereits im Access-Management-Versuch gelernt. Fügen Sie der Gruppe den Benutzer **sysing01** hinzu.

Öffnen Sie den Certification Authority Dialog. Rechtsklick auf **Certificate Templates** → **Manage** und duplizieren Sie das "**Code Signing**" Template.

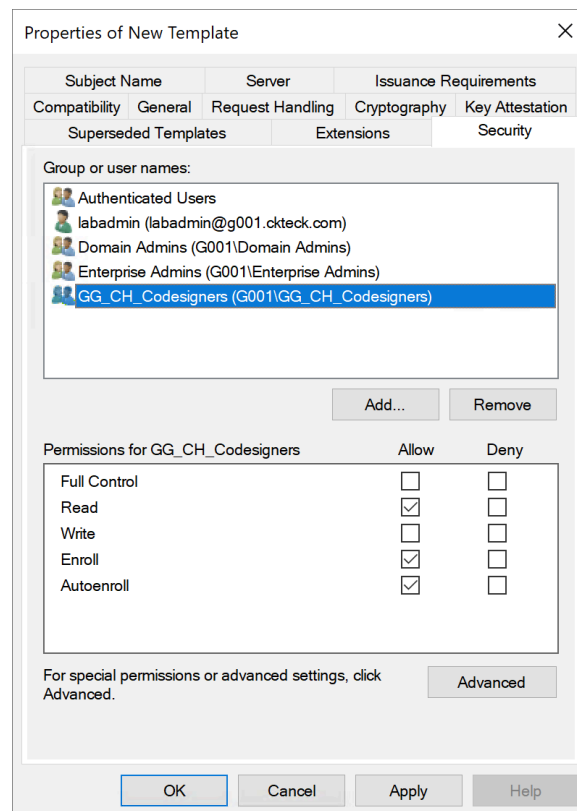


Abbildung 29: Dupliziertes “Code Signing” Certificate Template

Aktivieren Sie das neu erstellte Template mittels Kontextmenü der **“Certificate Templates → New → Certificate Template to Issue...”**.

Melden Sie sich neu am Windows-Client an, damit Sie das Zertifikat erhalten. Kontrollieren Sie in **Manage user certificates → Personal → Certificates**, ob Sie das Code Signing Zertifikat erhalten haben.

Um Sie vor der nächsten Stolperfalle zu bewahren, wird im Folgenden ein wenig vorgegriffen. Sie können nun zwar Scripts signieren, jedoch gelten Sie noch nicht als “Trusted Publisher” auf Ihrem Windows-Client.

Dazu muss Ihr Zertifikat zuerst verteilt und auf allen Windows-Clients in die “Trusted Publishers” aufgenommen werden. Dies kann zum Beispiel mittels Group Policy Management passieren.

Zuerst muss das gefragte Zertifikat bereitgestellt werden. Wechseln Sie auf Ihrem Windows-Server in den Certificate Authority Dialog und sehen Sie sich die ausgestellten Zertifikate an. Identifizieren Sie das Code Signing Certificate, welches für **sysing01** ausgestellt wurde. Exportieren Sie das Zertifikat im **BASE64**-Format.

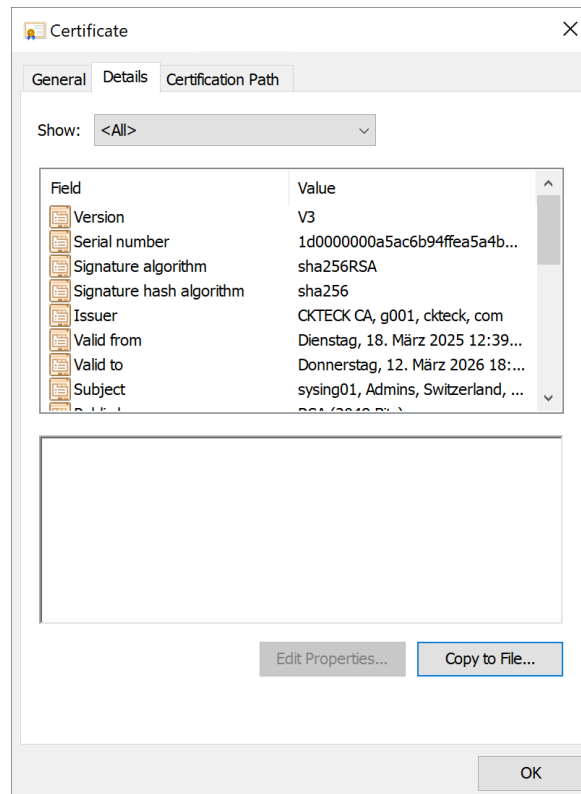


Abbildung 30: Detailansicht des ausgestellten Zertifikats

Öffnen Sie nochmals den Group Policy Management Editor. Navigieren Sie wie folgt:

Computer Configuration → Policies → Windows Settings → Security Settings → Public Key Policies → Trusted Publishers

Starten Sie mittels Kontextmenü den Import-Dialog und importieren Sie das gerade eben exportierte Code Signing Certificate.

Nun ist ein **gpupdate /force** notwendig, um die Einstellung auf dem Windows-Client zu aktualisieren. Kontrollieren Sie anschliessend im **Local Computer Certificate Store (certlm.msc)**, ob das Zertifikat am korrekten Ort erscheint.

5.4. Script signieren

Nun wollen wir das Script signieren. Öffnen Sie eine PowerShell Console und geben Sie folgenden Befehl ein. Passen Sie den Pfad zu Ihrem Script wenn nötig an.

```
1 Set-AuthenticodeSignature -FilePath .\script.ps1 -Certificate (Get-ChildItem -Path Cert:\CurrentUser\My\ -CodeSigningCert) -TimeStampServer http://timestamp.digicert.com
```

Aufgabe 5.8

Öffnen Sie das Script in einem Editor Ihrer Wahl. Sehen Sie sich das Script an. Was wurde hinzugefügt?

Lösung

Unter dem Skript Code wurde ein Block mit einer digitalen Signatur eingefügt.

Führen Sie das Script nochmals aus. Es sollte nun funktionieren.

Aufgabe 5.9

Öffnen Sie das Script erneut und verändern Sie etwas. Das kann zum Beispiel das Einfügen eines Kommentars mittels “#”-Zeichen sein. Speichern Sie.

Führen Sie das Script nochmals aus. Funktioniert das Script noch? Was für eine Meldung erscheint?

Lösung

Das Skript kann nicht mehr ausgeführt werden, da sich die Signatur verändert hat.

Es erscheint die Meldung: “script.ps1 might have been changed, hash does not match hash stored in digital signature.”

Signieren Sie das Script nochmals und führen Sie es nochmals aus. Stellen Sie sicher, dass das Ausführen des Scripts wieder funktioniert, bevor Sie weiterfahren.

5.5. Revocation-Problematik

Was passiert aber wenn ein Mitarbeiter, welcher Code signiert hat, die Unternehmung verlässt? Was passiert mit dem von diesem Mitarbeiter signierten Code? In diesem Kapitel werden Sie genau diesem Umstand nachgehen.

Wechseln Sie in die **Certification Authority** auf Ihrem Windows-Server und erklären Sie das vorhin ausgestellte Code-Signing-Zertifikat als ungültig. Gehen Sie analog zum **vorhergehenden Kapitel mit User Certificates** vor (CRL publizieren, Online Responder Revocation Data aktualisieren, um nicht warten zu müssen etc.). Damit simulieren wir den Austritt des Mitarbeiters.

Wechseln Sie nun wieder zurück zum Windows-Client. Versuchen Sie das Script nochmals auszuführen.

Aufgabe 5.10

Was passiert? Kann das Script noch erfolgreich ausgeführt werden? Warum ist das festgestellte Verhalten so?

Hinweis

Sehen Sie sich die Stammzertifikate von Microsoft im lokalen Certificate Store an. Warum hat es da schon längst abgelaufene Zertifikate drin? Die könnte man doch schon lange rauslöschen, oder etwa doch nicht?

Lösung

Ja, das Skript kann noch ausgeführt werden. Das ist sinnvoll, da sonst alle je signierte Software beim Ablauf des Zertifikats unbrauchbar würde (siehe alte Microsoft-Zertifikate).

Signieren Sie nun das Script erneut und speichern Sie es z.B. unter `C:\temp\`. Melden Sie sich als **sysing01** vom Windows-Client ab. Loggen Sie sich mit einem anderen Benutzer Ihrer Wahl ein (**kein** Domain Admin (**labadmin**) verwenden!).

Aufgabe 5.11

Öffnen Sie eine PowerShell Console und versuchen Sie das Script erneut auszuführen. Wie sieht es jetzt aus? Kann das Script ausgeführt werden? Warum ja/nicht?

Lösung

Das Skript kann nicht mehr ausgeführt werden, da es mit einem revozierten Zertifikat signiert wurde.

6. SSL Interception

Aufgabe 6.1

Beginnen wir dieses Kapitel mit einer Frage: Was bedeutet für Sie das “Schloss”-Symbol in der Adressleiste des Browsers?

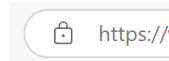


Abbildung 31: Browser-Adressleiste mit Schloss-Symbol

Information

Das “Schloss”-Symbol in der Adressleiste moderner Browser hat sich über die Jahre verändert. Während es früher oft grün dargestellt wurde, haben die meisten Browser-Hersteller inzwischen zu einer neutraleren, monochromen Darstellung gewechselt.

Lösung

Dies bedeutet, dass die Website über HTTPS bzw. mit TLS Verbindung aufgerufen wurde und das Zertifikat der Website gültig ist und der ausstellenden CA vertraut wird.

In diesem Versuch möchten wir Ihnen aufzeigen, dass E-Banking oder ähnliche vertrauliche Anwendungen nur in bekannten und vertrauenswürdigen Netzwerken genutzt werden sollten. Den Grund dafür werden Sie gleich selbst erkennen.

Für SSL Interception (das “Abfangen” verschlüsselter Verbindungen) wird ein Man-in-the-Middle (MitM) Aufbau benötigt. Das bedeutet, der gesamte Netzwerkverkehr muss über eine Zwischenstation laufen, bevor er die eigentliche Zielstelle (z.B. eine Webseite) erreicht. Der klassische MitM-Fall ist ein Hacker (nennen wir ihn Yuri), der sich mittels Spoofing-Methoden zwischen das Opfer und sein Ziel drängt. Es muss jedoch nicht immer ein böswilliger Angreifer sein – auch das Default Gateway jedes Geräts kann als MitM-Instanz betrachtet werden, da jeglicher Datenverkehr zu externen Netzwerken über dieses Gerät geleitet wird. Diesen Umstand werden wir mit Hilfe der OpenSource-Software **mitmproxy** demonstrieren.

Unser Szenario spielt im internen Firmenumfeld, wobei “der Systemadmin” die feindliche Rolle einnimmt. Dieses Szenario lässt sich jedoch ebenso gut auf öffentliche Hotspots wie an Flughäfen übertragen. Mehr dazu später.

6.1. **mitmproxy**

Die Webseite von **mitmproxy** beschreibt die Software mit folgenden Worten:

mitmproxy is your swiss-army knife for debugging, testing, privacy measurements, and penetration testing. It can be used to intercept, inspect, modify and replay web traffic such as HTTP/1, HTTP/2, WebSockets, or any other SSL/TLS-protected protocols. You can prettify and decode a variety of message types ranging from HTML to Protobuf, intercept specific messages on-the-fly, modify them before they reach their destination, and replay them to a client or server later on.

mitmproxy ist ein sehr mächtiges Werkzeug. In diesem Versuch werden wir nur einen Teil der gebotenen Funktionalität verwenden.

6.1.1. mitmproxy installieren

Wir werden den `mitmproxy` über `pipx` installieren. `pipx` verwendet den Python Package Manager `pip` (`pip install packages`), erstellt allerdings gleich automatisch ein virtual Environment und kümmert sich um die Pfade, damit die installierten Pakete direkt von der Befehlszeile als Anwendungen ausgeführt werden können.

Man könnte `mitmproxy` auch aus dem `apt-get`-Repository installieren, zum Zeitpunkt der Übungserstellung war die `mitmproxy`-Version aus dem `apt-get`-Repository jedoch veraltet. Darum wird hier auf `pipx` zurückgegriffen.

Wechseln Sie wieder auf Ihren Linux-Client. Vor der Installation des Pakets soll zunächst `pipx` installiert werden.

```
1 sudo apt update && sudo apt install pipx
2 pipx ensurepath
```

Öffnen Sie nun einen neuen Terminal-Tab oder führen Sie den folgenden Befehl aus, um die Änderung des letzten Befehls wirksam zu machen.

```
1 source .bashrc
```

Installieren Sie nun mittels `pipx` den `mitmproxy`.

```
1 pipx install mitmproxy
```

6.1.2. IP Forwarding aktivieren

Damit der Linux-Client Netzwerkverkehr anderer Geräte weiterleiten kann, müssen einige Konfigurationen vorgenommen werden.

Ändern Sie in der Datei `/etc/sysctl.conf` folgende Einträge entsprechend ab.

```
1 net.ipv4.ip_forward=1
2 net.ipv6.conf.all.forwarding=1
3 net.ipv4.conf.all.send_redirects=0
```

Um die durchgeführten Änderungen anzuwenden, muss folgender Command ausgeführt werden.

```
1 sudo sysctl -p /etc/sysctl.conf
```

Zusätzlich ist ein Reboot des Linux-Clients notwendig. Machen Sie einen Reboot über das Terminal. Wenn Sie das GUI verwenden, dann startet sich nur das GUI und nicht die ganze VM neu.

```
1 sudo reboot
```

In der momentanen Situation wird der Web Traffic einfach nur weitergeleitet. Es findet keine Interception statt.

Um den interessanten Traffic an den `mitmproxy` weiterzuleiten, müssen folgende `nftables`-Rules definiert werden. Der `mitmproxy` horcht lokal auf dem TCP Port 8080.

```
1 sudo nft add table inet nat
2 sudo nft add chain inet nat prerouting { type nat hook prerouting priority
  0 \; }
3 sudo nft add rule inet nat prerouting iifname "ens3" tcp dport 80 counter
  redirect to :8080
4 sudo nft add rule inet nat prerouting iifname "ens3" tcp dport 443 counter
  redirect to :8080
```

Aufgabe 6.2

Warum haben Sie `nftables`-Einträge für `inet` (IPv4 und IPv6) konfiguriert?

Erklären Sie das Verhalten Ihres Browsers, wenn Sie eine Webseite mit Dual Stack-Kompatibilität öffnen!

Hinweis

https://en.wikipedia.org/wiki/Happy_Eyeballs

Lösung

Happy Eyeballs bevorzugt Verbindungen über IPv6.

Starten Sie den `mitmproxy` im interaktiven Modus mit folgendem Befehl.

```
1 mitmproxy --mode transparent
```

6.2. Windows-Client vorbereiten

Loggen Sie sich als erstes wieder mit dem User `sysing01` ein.

Wichtig

Passen Sie auf, dass Sie beim Default Gateway keine Tippfehler machen! Ansonsten sperren Sie sich selbst aus!

Ändern Sie das Default Gateway auf die IPv4-Adresse des Linux-Clients. Die IP-Adresse und die Subnetzmaske des Windows-Clients bleiben unverändert.

6.3. Testing

Öffnen Sie auf Ihren Windows-Client eine Webseite, die HTTPS erzwingt. Heutzutage sind dies die meisten. Ein Beispiel ist <https://meteo.ch>.

Aufgabe 6.3

Wie sieht es aus? Funktioniert es? Treten Probleme auf?

Schauen Sie sich das Resultat im Windows Client und in der `mitmproxy`-Console an.

Lösung

Ja, die Website kann noch angezeigt werden, jedoch erhält man die Meldung `ERR_CERT_AUTHORITY_INVALID`.

Dem Zertifikat für die Website meteo.ch scheint also nicht vertraut zu werden.

Alle Requests sind in der `mitmproxy`-Konsole ersichtlich.

6.4. Eigene Certificate Authority einbinden

Wie Sie gemerkt haben, läuft noch nicht alles rund. Der Client sieht sofort, dass hier etwas nicht stimmt. Ihnen wird eine grosse Zertifikatswarnung angezeigt. In diesem Kapitel werden Sie eine Subordinate CA unter Ihrer eigenen Subordinate CA erstellen.

Zuerst muss erneut ein Certificate Request erstellt werden. Führen Sie den Befehl auf dem Linux-Client aus. Unter anderem werden Sie aufgefordert, ein Verschlüsselungspasswort für den Private Key einzugeben. Merken Sie sich dieses, da Sie es gleich wieder brauchen werden.

```
1 openssl req -new -newkey rsa:4096 -keyout mitmproxyc-private.key -out subca.csr
```

Öffnen Sie nun wieder den Certificate Enrollment Web Service. Sie finden diesen wieder unter `http://gXXX.ckteck.com/certsrv`. Gehen Sie gleich wie beim Request für das Webserver Zertifikat vor, wählen Sie jedoch diesmal **“Subordinate Certification Authority”** als Certificate Template.

Laden Sie die **Certificate Chain im BASE64-encodierten Format** herunter. Gleich wie schon beim Webserver muss das Format der Certificate Chain angepasst werden. Verwenden Sie dazu nochmals folgenden Befehl (passen Sie Dateinamen etc. auf Ihre Umgebung an):

```
1 sudo openssl pkcs7 -print_certs -in subcachain.p7b -out /etc/ssl/certs/mitmproxy-ca.pem
```

`mitmproxy` benötigt das Zertifikat plus den Private Key im gleichen PEM-File. Dies bedeutet für Sie, dass Sie den Inhalt des zuvor erstellten Private Key Files unten an die Datei `“mitmproxy-ca.pem”` anhängen müssen. Vergessen Sie nicht, die Datei zu speichern.

Starten Sie als nächstes den `mitmproxy` mit folgendem Befehl:

```
1 mitmproxy --mode transparent --set confdir=/etc/ssl/certs --set cert_passphrase=<Verschlüsselungspasswort>
```

Falls ein Fehler auftritt, prüfen Sie, ob Sie wie oben beschrieben, den Private Key dem PEM-File angehängt haben. Beim Testing haben die Probanden diesen Schritt häufig vergessen. Vergewissern Sie sich ebenfalls, dass Sie die vorherige Instanz von `mitmproxy` beendet haben, bevor Sie die Software erneut starten.

6.5. Testing zum Zweiten

Navigieren Sie nun vom Windows-Client zu der, bei Studierenden sehr beliebten, Webseite <https://elearning.hslu.ch/>. Loggen Sie sich mit **falschen** Angaben in der ILIAS-Login-Maske für ehemalige Studierende ein.

Aufgabe 6.4

Wechseln Sie zur `mitmproxy`-Console und suchen Sie im `mitmproxy`-Log nach Ihrem Login-Versuch. Mit “Enter”, “Q” und den Pfeiltasten können Sie in den einzelnen Requests navigieren. Maximieren Sie das Terminal-Fenster damit alle Informationen dargestellt werden. Finden Sie Ihre zuvor eingegeben Login-Daten? Wo finden Sie diese? Beschreiben Sie!

Lösung

Es gibt einen `POST`-Request – im Request sind im Abschnitt `URLEncoded form` der `username` und das `password` in Klartext ersichtlich.

6.6. Funktionsanalyse

Nachdem Sie gesehen haben, dass mit Hilfe der `mitmproxy`-Software HTTPS (SSL) Verbindungen abgehört werden können, werden wir in diesem Kapitel die Funktionsweise der Software genauer unter die Lupe nehmen.

Aufgabe 6.5

Wo könnten Sie mit der Funktionsanalyse der Software beginnen? Wo könnten Sie gegebenenfalls überall ansetzen? Nennen Sie ein paar Beispiele!

Lösung

Dokumentation von MitM Proxy. Zertifikat der Website anschauen. SSL-Interception-Theorie.

Aufgabe 6.6

Untersuchen Sie die Funktionsweise an den von Ihnen oben genannten Stellen. Dokumentieren Sie Ihre Findings!

Lösung

Die Requests vom Windows-Client werden über den Linux-Client (`mitmproxy`) an das eigentliche Ziel weitergeleitet. SSL Termination beim Proxy. Von Proxy zu Website wird eine neue SSL-Verbindung aufgebaut.

Sollten Sie verunsichert sein, wo Sie anfangen sollen, starten Sie mit der Analyse des Zertifikats der ILIAS-Webseite auf Ihrem Windows-Client. Beantworten Sie folgende Fragen.

Aufgabe 6.7

Wer ist der Issuer des Zertifikats?

Lösung

CKTECK CA

Aufgabe 6.8

Wie sieht der Certification Path aus?

Lösung

Root CA CKTECK → CKTECK CA → Internet Widgits Pty

Aufgabe 6.9

Machen die obigen Werte im Zusammenhang mit einer HSLU-Webseite Sinn?

Lösung

Nein die Werte machen keinen Sinn, hier sollte das Zertifikat der HSLU sein. Digicert oder ähnlicher Issuer.

Öffnen Sie noch ein paar weitere bekannte Webseiten Ihrer Wahl und studieren Sie die HTTPS-Zertifikate der Webseiten.

Wir schlussfolgern also, dass `mitmproxy` für jede besuchte Website ein neues Zertifikat anlegt. Diesem wird von unserem Client vertraut, da der ausstellende CA grundsätzlich vertraut wird.

6.7. Aufräumen

Um Konflikte mit darauffolgenden Übungen zu vermeiden, entfernen Sie die `nftables`-Regeln wieder.

```
1 sudo nft delete table inet nat
```

6.8. Schlusswort

Kommen wir auf den einführenden Teil dieses Kapitels zurück. Wie Sie in diesem Versuch gesehen haben, bedeutet das Schloss-Symbol im Browser nicht automatisch, dass eine absolut sichere Verbindung zwischen Ihnen und der von Ihnen angesurften Webseite besteht.

Wie Sie auch gesehen haben, wird einem wildfremden Zertifikat des Proxy-Servers glücklicherweise nicht einfach blind vertraut.

Wird jedoch ein Zertifikat verwendet, welches bereits als vertrauenswürdig gespeichert ist, merkt man ohne genaueres Hinschauen nicht, ob die SSL-Verbindung wirklich sicher ist. Diesen Fall haben Sie in diesem Laborversuch mittels interner CA umgesetzt.

Heisst das, wenn man mit seinem privaten Gerät ein wenig vorsichtig ist und rote Meldungen beachtet, ist man sicher? Nein! Weit gefehlt! Lesen Sie den folgenden Abschnitt:

Im Jahre 2011 wurde die holländische Certification Authority DigiNotar Opfer eines Hackerangriffs. Dabei wurden über 500 betrügerische Zertifikate für Google, Yahoo!, Mozilla, Wordpress etc. ausgestellt.

Lesen Sie den Wikipedia-Artikel zu obigem Vorfall: <https://en.wikipedia.org/wiki/DigiNotar>

Diese Zertifikate waren nicht von originalen Zertifikaten zu unterscheiden, da sie von einer legitimen Stelle ausgestellt wurden. Jedoch waren die jeweiligen Zertifikate nur für eine Domain gültig.

Zertifikatsfälschungen sind also durchaus möglich! Dazu kommen Certificate Authorities, die in Ländern mit restriktiver Überwachung, als wir sie kennen, zuhause sind. Es ist nicht zu kontrollieren, für wen diese CAs welche Zertifikate ausstellen.

Lesen Sie den folgenden Artikel. Dieser zeigt, dass das oben beschriebene Beispiel durchaus in der Praxis vorkommen kann.

<https://www.heise.de/news/Trustwave-verkaufte-Man-in-the-Middle-Zertifikat-1429722.html>

7. Anhang

7.1. Anhang A – Ablauf Signieren

Folgende Grafik zeigt den Prozess einer digitalen Signatur. Der Unterschreibende wendet einen Hash-Algorithmus auf die zu signierenden Daten an und verschlüsselt diesen Hash mit seinem eigenen Private Key. Diese Message wird Signatur genannt und an die Daten angeheftet.

Der Empfänger der Nachricht verwendet den gleichen Hash-Algorithmus und rechnet diesen über dieselben Daten. Er erhält nun ein eigenes Resultat für den Hash-Algorithmus und vergleicht dieses Resultat mit dem vom Absender angehängten. Dabei wird der öffentliche Schlüssel des Signierenden verwendet, um den Hash zu entschlüsseln.

Stimmt der selbstberechnete Hash mit dem mitgesendeten Hash überein, kann davon ausgegangen werden, dass sich die Daten seit dem Unterzeichnen nicht verändert haben und die Nachricht wirklich vom Signierenden stammt.

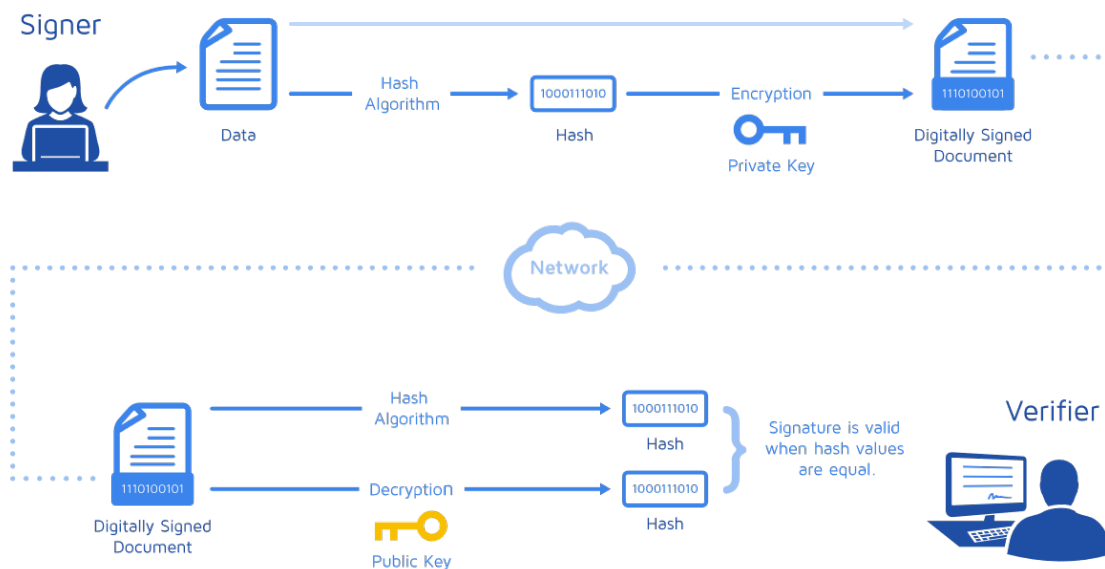


Abbildung 32: Ablauf Signieren (<https://medium.com/@meruja/digital-signature-generation-75cc63b7e1b4>)

7.2. Anhang B: Zertifikatsbasierte, gegenseitige Authentifizierung

Folgende Grafik zeigt den Prozess der zertifikatsbasierenden, gegenseitigen Authentifizierung. Dabei überprüft der Client zuerst das Zertifikat des Webserver. Danach übergibt der Client sein Client-Zertifikat dem Webserver, welcher dieses wiederum gegenüber der ausstellenden CA verifiziert. In unserem Fall ist die ausstellende CA für das Webserver- und das Client-Zertifikat ein und dieselbe. Das muss allerdings nicht zwingend immer der Fall sein. In der Praxis werden für die beiden Arten von Zertifikaten meist unterschiedliche CAs verwendet.

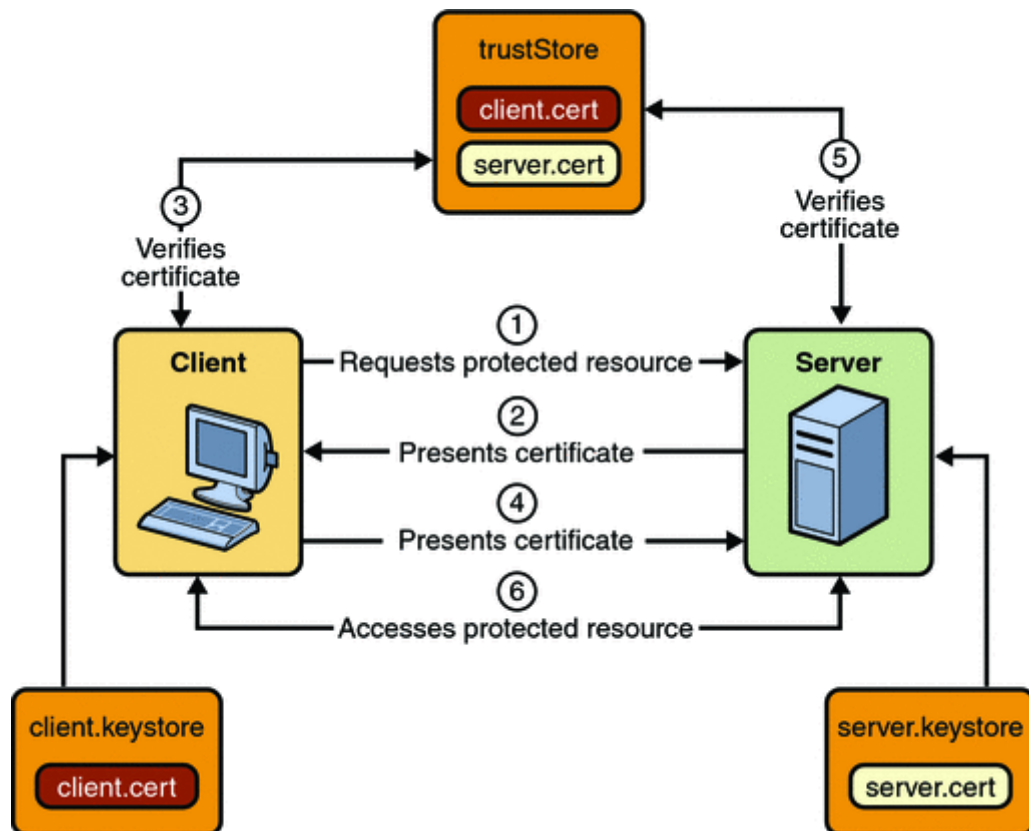


Abbildung 33: Zertifikatsbasierte, gegenseitige Authentifizierung
(<https://docs.oracle.com/cd/E19226-01/820-7627/bncbs/index.html>)

Notizen